

CodeTrackr — Complete Interview Preparation

Built from a full read of the repository on **2026-09-07**, branch `feat/security-and-insights`. Every claim here is traceable to a file. Sections are marked **[ACTUAL IMPLEMENTATION]** or **[RECOMMENDED IMPROVEMENT]** so you never accidentally claim something you didn't build.

Companion files: `CodeTrackr_Architecture.md` (diagrams + data flow), `CodeTrackr_Interview_QA.md` (question bank), `CodeTrackr_Interview_Cheat_Sheet.md` (revision), `../../CODETRACKR_PROJECT_CONTEXT.md`.

⚠️ CHANGED 2026-09-08 — the ingest write model. Where this doc says "one Activity document per flush", the backend now **\$inc-upserts a 10-minute (user, project, language) bucket** (`services/activityBucket.js`), the extension (2.3.0) **skips signal-less flushes** and defaults `minFlushMinutes` to 2, the analytics sub-docs are **sparse**, the `date` field is **gone**, and there's a `DailySummary` nightly rollup + 400-day TTL. Totals are unchanged (`$inc.duration` is real seconds); time-of-day precision is now the 10-minute grid. `ACTIVITY_BUCKET_MS=0` restores the old per-flush inserts. See `CodeTrackr_DB_Write_Reduction.md` and `docs/superpowers/{specs,plans}/2026-09-08-*`.

October 2026 update — read this first (added 2026-10-03)

This document was written before the October 2026 roadmap (`docs/ROADMAP_2026-10.md`). That work is **deployed (2026-10-03, commit 11040c5)** and **Google login works on the live site**. Not done yet: the live data migrations (so the leaderboard still uses the old scan). Extension **2.5.0 is live on the Marketplace since 2026-10-04** (Sign In, offline queue, keychain), so "live" is right for those too. **Wherever the text below disagrees with this box, this box wins.** Up-to-date short versions: `CodeTrackr_Interview_Cheat_Sheet.md` (rewritten) and `docs/INTERVIEW_PREP.md`. Measured numbers: `docs/BENCHMARKS.md`.

Topic	Old text says	Now
Extension API key	plaintext, non-expiring, unscoped; in <code>settings.json</code>	<code>ct_<id>_<secret></code> , DB stores SHA-256 of the secret (<code>id</code> lookup + <code>timingSafeEqual</code>), shown once; device-code sign-in issues per-device keys that expire in 1 year and can be revoked one by one; extension keeps the key in SecretStorage
Leaderboard	$O(\text{all activity} + \text{all users})$ scan per request (H-7/H-8)	<code>userstats</code> running totals updated on every write; all-time board = 3 indexed reads. 1M rows: p50 6.72 s → 62 ms (local benchmark). Group boards too; contest windows ? <code>from=&to=</code>

Topic	Old text says	Now
Cheating	a valid key + loop inflates hours (H-21)	credited time = min(duration, focus + 120 s), ≤ 600 s per user per 10-minute window via an atomic counter, long uploads spread; per-key quota; raw claim kept
Duplicates / offline	no idempotency; memory-only buffer, lost on restart	flushId receipts (applied once); persisted outbox in globalState, FIFO, survives restart (M-30 fixed)
Analytics	find() then JS reduce (M-1)	daily/weekly from one \$facet pipeline, proven equal to the old code by an oracle test
Write reduction	"~10× fewer writes"	measured: 4.9× fewer documents, 12.7× less data at the 2-minute cadence (19.6× / 51× vs the old 30 s); same throughput
Tests	18 suites / 296; nothing against a real DB	unit 27 suites / 375, 41 integration tests (supertest + in-memory MongoDB, incl. CORS preflight), extension 6 / 70, frontend 52 (Vitest + Testing Library, run in IST)
userId type	String on activities (M-6)	ObjectId migration in progress (reads accept both; script converts)
Teams	orphaned page + live API	deleted
Groups	no admin powers	creator can rename / remove members; ownership passes on when the creator leaves
Ops	no Docker, no CD, console logs	Dockerfile + CI health check; docker compose up runs MongoDB + API + website locally (verified); deploy-on-green (off until a secret), JSON logs with request ids, optional Sentry that receives every log.error (requests, route 500s, jobs, crashes)
Bugs found while building	—	H-23 CORS lacked PATCH → goal completion and mark-as-read never worked in a browser; M-31 goal window; M-32 weekly window; H-22 IST "today"; email leaks M-28/M-29; H-24 (found live 2026-10-04) the all-time boards trusted running totals before the backfill had run, so they listed only people who had uploaded since the deploy; M-37 deleted "deadline missed" notices came back every hour (now recorded on the goal and claimed atomically)

Topic	Old text says	Now
Web login / API address	SPA calls Render directly (VITE_API_URL); login cookie is cross-site (SameSite=None); rate limits per IP	Vercel forwards /api + /auth to Render ; the production site calls its own address (config.ts: API_URL = ''), so the cookie is first-party (still SameSite=None during the switch); Google's callback goes through the website; browser-facing limits per user/session (rateLimitKeys.js). Live 2026-10-03
Website (redesigned 2026-10-04, built, not deployed)	3D background, glitch text, custom cursor, 28 themes; 1,150-line Dashboard; Chart.js; no public page; no frontend tests	"The weekly race": an F1-style standings tower (position, one cell per day, gap), race chart, landing + guide + privacy pages, invite links /join/:id, dark + light themes as CSS variables; hand-made SVG charts (no chart library); every page lazy-loaded: landing first visit 748 → 359 kB (232 → 114 kB gzip) ; 52 Vitest tests; found + fixed: goals saved a day early in India (M-34); sign-out landed on the sign-in page (D-37). Spec docs/specs/2026-10-04-frontend-redesign.md, D-31..D-36
Still open	—	H-19 login fix live (Vercel forwards /api + /auth; Google login works on the deployed site; Safari/private-window check pending); a failed Google sign-in shows raw JSON (M-33); goal progress misses the deadline day (M-35); no self-serve data deletion (L-14); client-chosen timestamps, no web refresh token; the API still runs end-of-life Node 20 (L-15). H-20 fixed (limits per user/session)

Table of contents

1. Project overview & elevator pitches
2. Architecture
3. Technology stack (with alternatives & trade-offs)
4. The VS Code extension — in depth
5. The unique-key / account-linking system
6. Database design (MongoDB / Mongoose)
7. Backend & API architecture
8. Frontend architecture
9. Analytics processing
10. Leaderboard
11. Groups

12. Insights / ML system
 13. Authentication & authorization
 14. Security analysis
 15. Error handling & reliability
 16. Performance & scalability (10k → 1M users)
 17. Testing
 18. Debugging playbook
 19. Deployment / DevOps
 20. Design decisions — "why did I choose this?"
 21. Known limitations
 22. Future improvements roadmap
 23. Time & space complexity
 24. Code-level questions
 25. Codebase map
 26. "Defend your project" — 30 interviewer exchanges
 27. Final self-audit
 28. Core computer-engineering subjects — where each one actually appears
-

1. Project overview & elevator pitches

What it is [ACTUAL IMPLEMENTATION]

Why it exists (the motive): to keep **friendly competition** going in my college friend group. You create a **group** — for a contest week, or just to keep each other honest on daily practice — and because everyone's editor is tracked automatically, the group page shows who actually put in the hours and the code. The extension also records each person's **command / build / test failures**, so "who's fighting the most errors this week" is data the app already collects — and since 2026-09-10 the group leaderboard shows it: commits, failed commands and failed builds per member, with failure rates.

CodeTrackr is a **developer-productivity analytics platform** with three parts that share one backend:

1. A **VS Code extension** that passively records coding activity (time, files, languages, editor edits, terminal commands + their success/failure, git commits, focus/flow) and sends it to the backend on a timer.
2. A **Node/Express/MongoDB backend** that authenticates the extension by an **API key**, normalises the payload, and **merges it into a 10-minute activity "bucket" document** (`$inc` upsert — changed 2026-09-08; was one document per flush), then serves aggregated analytics to the dashboard.
3. A **React dashboard** that visualises a user's activity (daily/weekly charts, terminal analytics), plus the social layer — **groups** with their own per-member leaderboards (the core feature), a **global leaderboard**, **goals** on a calendar with deadline notifications — and a private **Insights** page of derived productivity metrics (deep-work ratio, flow blocks, consistency, true peak hour, estimation accuracy).

Auth is split: the **web** uses Google OAuth → a JWT in an httpOnly cookie; the **extension** uses a per-user random API key in an `x-api-key` header.

The one honest caveat to lead with

The "ML/Insights" layer is **deterministic statistics**, not machine learning — coefficient of variation, weighted scoring, medians, computed on demand in pure JavaScript. I scoped it that way on purpose (explainable, reproducible, no training data needed). An LLM narration layer is *designed* in `docs/TRACKING_ROADMAP.md` but not built.

30-second version

"CodeTrackr is a coding-activity tracker built around friendly competition. My friends and I wanted to see who was actually putting in the work during contest weeks and daily practice, so I built a VS Code extension that quietly records what you work on — time per language, editor churn, terminal commands and whether they passed or failed, git commits — and sends it to my backend. You make a group with your friends, and the app shows a per-member leaderboard plus a global one, goal tracking, and an insights page for things like your most productive hour. It's a MERN stack — React, Express, MongoDB — plus a TypeScript VS Code extension."

1-minute version

"The idea came from my friend group — during coding contests and daily practice we kept arguing about who'd actually done the work, so I built something to measure it. A VS Code extension in TypeScript hooks into editor, terminal, git and window events and accumulates counters — gross lines edited, churn, focused minutes, flow blocks, command and build success rates. The extension flushes those to an Express API, authenticated by a 64-character API key the user gets from the website after signing in with Google. The backend merges each flush into a 10-minute activity document in MongoDB and exposes aggregated endpoints. The React frontend renders daily and weekly charts with Chart.js; **groups** you create and join (public or password-protected) with a per-member leaderboard of hours and lines; a global leaderboard; goals on a calendar with a node-cron job that fires deadline notifications; and an Insights page that derives confidence-gated productivity metrics using plain statistics. Deployed with the frontend on Vercel, the backend on Render, and MongoDB Atlas."

2-minute version

Add, after the 1-minute version:

"The interesting design problem was linking the extension to the account without a full login flow inside VS Code. I went with an API-key model: on first Google sign-in the backend generates `crypto.randomBytes(32)` hex and stores it on the user; the extension sends it as a header; the backend does `User.findOne({ apiKey })` and attaches that user to the request. It's simple and it works, but in a review I'd call it what it is — an unscoped, non-expiring bearer credential stored in plaintext — and I can walk through how I'd harden it.

The other thing I'm proud of is the tracking accuracy work. The naive version measured time as wall-clock elapsed and lines as the net change in `document.lineCount`, which reports zero for any refactor that replaces code in place. I rewrote the trackers to accumulate gross insert/delete counts and a churn

metric — lines you wrote then deleted within ten minutes — and to only count focused time, with 'flow blocks' that capture the shape of a session, not just its total. Those feed the Insights page.

I also did a security and correctness audit of my own code — there's an `IMPROVEMENT_PLAN.md` with 30-odd findings — and closed the high-severity ones: analytics endpoints were readable by user id with no ownership check, group passwords were plaintext, there was an `AUTH_BYPASS` env flag that disabled all auth. Those are fixed on the current branch with tests that statically scan the routes and fail if the auth middleware ever disappears."

5-minute deep technical version

Cover, in order: (0) the motive — friendly competition in a friend group, so the **group** + its per-member leaderboard is the heart of the product, everything else is measurement to feed it; (1) the three-client / one-backend topology and why a modular monolith; (2) the extension's tracker architecture — `consumeInterval()` contract, idle/pause state machine, `payloadHasSignal` skip-empty, no offline queue; (3) the ingest path — `verifyApiKey`, additive normalisers that tolerate old payloads, `planActivityWrite` → **10-minute bucket \$inc upsert** (`ACTIVITY_BUCKET_MS=0` = legacy per-flush create); (4) the read path — `isAuthenticated` + `assertOwnership`, `Activity.find` then JS aggregation, and why that's a known M-1 that should move into MongoDB `$group`; (5) the leaderboard's full-collection scan and the `UserStats` rollup you'd build instead; (6) the Insights pipeline — `metricsService` (DB) + `metricsDerive` (pure, unit-tested) and the honest "this is stats not ML" line; (7) auth — Google OAuth → JWT cookie for web, API key for the extension, no refresh token, `session:false`; (8) the security findings you found and fixed vs the ones still open; (9) deployment — Vercel + Render + Atlas, and the `node-cron`-on-serverless problem; (10) what you'd do next — hash keys, add a queue and a rollup, adopt React Query, fix the the (now-fixed) TS errors landed 2026-09-09; add integration tests next.

"Tell me about your project."

"CodeTrackr is a coding-productivity tracker I built with two friends. It came out of our own habit — during coding-contest weeks and daily practice we'd all claim we'd 'grinded', and there was no way to actually see it. So the core loop is: a VS Code extension records your activity and sends it to my backend, and a React dashboard shows it. The feature that matters is **groups** — you make a group with your friends and get a per-member leaderboard of who coded the most, in what languages, and how their command/build success compares. On top of that there's a global leaderboard, goal tracking, and a stats-based insights page. My focus areas were the extension's tracking accuracy, the backend API and data model (including a recent change to merge flushes into 10-minute buckets so the write volume doesn't explode), and a self-audit that turned into a security pass. The part I'd most want to talk through is the account-linking design — how the extension authenticates without a login UI — because it's a real trade-off and I know exactly where it's weak."

"What was your contribution?" [ground this ONLY in repo evidence]

The repo's git identity is **Soham Budhewar**; `extension/package.json` credits three contributors (Pratik Jambhule, Kartik Kharat, Soham). Honest phrasing:

"I worked across the stack. On the extension I built/rewrote the tracker layer — the editor, focus and git-state trackers with the `consumeInterval` reset contract, the idle-pause state machine, and the payload

assembly — and fixed the packaging bug where `vsce` shipped stale code because `prepublish` never ran `tsc`. On the backend I built the metrics service and the derived-metrics module, the authorization and password-hash services, the activity normalisers, and the tests. I also did the codebase audit that produced `IMPROVEMENT_PLAN.md` and closed the high-severity security items. I can't claim the whole frontend — the dashboard and the decorative components predate my heaviest work — but I added the Insights page and the ownership checks that made the analytics endpoints safe to call with `credentials: 'include'.`"

(Adjust to your real split. The safe move in an interview is to describe what you can explain in depth, not to claim ownership of code you'd struggle to defend.)

Why I built it

"My friend group runs informal coding contests and daily practice streaks, and there was always the same argument — everyone *says* they put in the hours. I wanted a way to just see it: make a group, everyone installs the extension, and the group page shows who actually coded, in what languages, and — because the extension records failed commands/builds too — roughly who was fighting the most errors. The personal side (focused vs elapsed time, churn, most-productive hour) grew out of the same 'measure it honestly' idea. WakaTime measures time-in-editor but has no group-competition angle and doesn't tell you whether the time was focused or churning."

What problem it solves / what makes it different

- **Problem:** in a group of friends who code together, there's no honest, low-effort way to see who's actually doing the work — self-reported effort is unreliable and nobody wants to manually log anything.
- **Different from a plain tracker:** (1) it's built around a **group leaderboard** — the competition is the point, not a side feature; (2) it records **command/build/test success and failure** per person, not just time; (3) it measures **focused** time and **flow blocks**, not just elapsed; (4) it tracks **churn** (write-then-delete) so a refactor isn't invisible; (5) it separates "busiest hour" from the most productive **2-hour window**, scored on surviving minutes, and compares your goal **estimates** to hours actually logged.

Hardest part / biggest technical challenge

"Getting the *time* number honest. The first version counted wall-clock elapsed from session start, so leaving VS Code open inflated everything. Then it counted lines as the delta of `document.lineCount`, which is zero for a replace-in-place edit — i.e. most refactoring. I ended up building a small state machine: mark activity on real editor/nav events, pause after two minutes idle, buffer active minutes, and flush with the timestamp of the *start* of the interval so hour-of-day analytics aren't skewed forward. The editor tracker accumulates gross insert/delete counts and attributes deletions against recent insertions to compute churn. All of that is unit-tested against the built bundle with a stubbed `vscode` module."

What I'd improve

Top three: (1) hash the API keys and support rotation with a grace window / per-device keys; (2) replace the leaderboard's full-collection scan with a `UserStats` rollup updated on ingest; (3) move analytics aggregation

from JavaScript into MongoDB `$group` pipelines and add the `{userId:1, timestamp:-1}` index (shipped 2026-09-08). The 29 TypeScript errors were fixed 2026-09-09 so `npm run build` passes, and add integration tests that actually hit a database.

2. Architecture

(Diagrams and full data-flow walkthroughs are in `CodeTrackr_Architecture.md`. Summary here.)

Shape [ACTUAL IMPLEMENTATION]

- **Client-server**, three clients (extension, SPA, and — trivially — `curl`) against **one** Express backend and **one** MongoDB.
- **Modular monolith**: a single Node process; features are separate Express routers under `backend/routes/`. One deploy unit, one connection pool.
- **RESTish**: resource URLs + JSON + HTTP verbs; some RPC-ish paths (`/groups/:id/join`).
- **Partial MVC + thin service layer**: Mongoose models = M; routers = C; React = V. Services exist only for `metrics`, `authorization`, `passwordHash`, `activityNormalizers`, `notificationScheduler`. Everything else is route → Mongoose directly.
- **No** message queue, cache, gateway, search index, or WebSockets. NotificationPanel **polls** every 30 s.

Why this architecture

"It's a student/side project with one backend developer at a time and a free-tier budget. A monolith deploys as one Render service, debugs in one process, and has no cross-service consistency problems. The features genuinely share one data model — everything hangs off the `activities` and `users` collections — so splitting them into services would add network hops and distributed-transaction problems for zero benefit at this scale. The parts that *would* justify extraction later (high-volume ingest, heavy leaderboard aggregation) are exactly the parts I've identified for a queue + worker + rollup evolution."

Request lifecycles

Ingest: `POST /api/extension/track` → CORS (no Origin from a server-to-server call, so allowed) → `express.json()` → `verifyApiKey (User.findOne({apiKey}))` → handler validates `fileName/language/duration` → `normalize*Analytics()` → `Activity.create()` → 201.

Dashboard read: `GET /api/analytics/:userId` → `express.json / cookie-parser` → `isAuthenticated (jwt.verify(req.cookies.token) → User.findById)` → `resolveOwnedUserId (assertOwnership, 403 on mismatch)` → `Activity.find({userId, timestamp:{$gte:7d}})` → JS `.filter/.reduce/Map` → `res.json`.

Insights: `GET /api/metrics` → `isAuthenticated` → `buildMetrics(req.user._id)` (4 `Activity.aggregate` calls) → `metricsDerive` pure functions → `res.json`. **No :userId param at all** — identity comes only from the session, which makes this endpoint IDOR-proof by construction.

3. Technology stack (with alternatives & trade-offs)

For each: **what / where in CodeTrackr / why / alternative / why the choice holds / interview Qs.**

React 19 + Vite 7 + TypeScript

- **Where:** the entire dashboard SPA (frontend/). ~7,300 lines of TSX. Components, hooks (`useState`, `useEffect`, `useCallback`, `useRef`, `useContext`), one context (`ThemeContext`), `react-router-dom` v7 for routing, prop-drilling for the `user` object.
- **Why:** component model fits a dashboard of many independent widgets; huge ecosystem; Vite gives sub-second HMR and a simple `vite build`; TS catches shape errors on API responses.
- **Alternative:** Next.js (SSR/SEO, file routing, API routes co-located) — rejected because the app is auth-gated and behind a login, so SEO is irrelevant and SSR adds a server to operate. Svelte/Vue — smaller bundles, but React's ecosystem (Chart.js wrapper, lucide icons) and team familiarity won.
- **Trade-off / where it bit me:** no data-fetching library — every navigation refetches with `cache: 'no-cache'`. `@tanstack/react-query` is even in `package.json`, unused (M-12). `tsc -b` had **29 errors** so `npm run build` failed — ✅ fixed 2026-09-09 (M-13), CI enforces it.
- **Interview Qs:** "Why not Next.js?" / "How do you manage server state?" / "What breaks with StrictMode double-invoke?" / "Why is `useCallback` on `fetchAnalytics`?"

Node.js 18 + Express 5

- **Where:** `backend/. app.js` wires middleware and mounts 10 routers.
- **Why:** same language as the frontend and extension; Express is the smallest thing that does routing + middleware; Express 5 gives native async error propagation (a rejected promise in a handler becomes a 500 without `next(err)` — and there's now a central error handler so it's still a generic 500).
- **Alternative:** Fastify (faster, schema validation built in, would have covered M-4); NestJS (structure, DI, decorators — would have forced the service layer I only half-built); a Python/FastAPI backend if the ML plan were real.
- **Trade-off:** Express gives you nothing for free — no validation, no security headers, no rate limiting. `helmet` and `express-rate-limit` and `express-validator` are all installed and **not wired in** (M-3/M-4).
- **Interview Qs:** "Express 4 vs 5?" / "How does async error handling work here?" / "Where's your validation layer?"

MongoDB + Mongoose 8

- **Where:** the only datastore. `activities` (high volume — one doc per 10-minute (`user`, `project`, `language`) window since 2026-09-08, previously one per flush), `users`, `groups`, `groupmembers`, `goals`, `teams`, `notifications`, `dailysummaries` (nightly rollup).
- **Why:** activity documents are **append-only, self-contained, and schema-evolving** — I added three analytics sub-documents (`editorAnalytics`, `focusAnalytics`, `gitAnalytics`) additively with no migration, because Mongoose ignores unknown fields on read and defaults missing ones. The dominant access pattern is "all of one user's docs in a window, then aggregate" — no joins on the hot path. Mongoose gives schema validation and a familiar model API.
- **Alternative:** PostgreSQL — better for the *relational* parts (`groupmembers`, `teams.members`, goal ownership) where FKs and transactions matter, and dramatically better for the leaderboard, which is a `GROUP BY user_id` that Postgres does with a covering index instead of loading the whole table into Node. A time-series DB (Timescale, Influx) would fit the activity stream even better.

- **Trade-off:** no transactions anywhere; `activities.userId` is a `String` while everything else is `ObjectId`, which blocks `$lookup` (M-6) — the leaderboard groups by the string and matches users in Node; the leaderboard scan (H-7) is a direct consequence of "aggregate in the app, not the engine".
- **Interview Qs:** the whole of §26 exchanges 1–6.

VS Code Extension API (@types/vscode ^1.85) + esbuild

- **Where:** `extension/`. Events consumed: `workspace.onDidChangeTextDocument`, `onDidSaveTextDocument`, `window.onDidChangeActiveTextEditor`, `workspace.onDidOpenTextDocument`, `window.onDidChangeWindowState`, `window.onDidStart/EndTerminalShellExecution`, `debug.onDidStart/TerminateDebugSession`, `debug.onDidChangeBreakpoints`, and the built-in `vscode.git` extension's `repo.state.onDidChange`.
- **Why esbuild:** bundles `src/extension.ts` + all `src/*.ts` + `axios` into one `dist/extension.js` in milliseconds, `--external:vscode` (provided by the host). `vsce` packages that.
- **Alternative:** webpack (the VS Code default — slower, more config); `tsc` alone (no bundling, ships `node_modules`). `SecretStorage` instead of settings for the key (should have).
- **Trade-off:** `tsconfig` is `strict: false` (L-6); a stale `dist/` once shipped because `vscode:prepublish` ran `esbuild` but not `tsc` (fixed in 2.0.11).
- **Interview Qs:** §4 in full.

JSON Web Tokens (jsonwebtoken) + Passport (passport-google-oauth20) + cookie-parser

- **Where:** `routes/auth.js` signs the JWT on OAuth callback; `middleware/auth.js` verifies it from the `token` cookie. `config/passport.js` is the Google strategy.
- **Why:** OAuth means no password storage for users; a stateless JWT in an `httpOnly` cookie means no session table and it survives a serverless cold start.
- **Alternative:** server-side sessions (`express-session` + a store) — easier revocation, but needs shared state; Auth0/Clerk — less code, external dependency.
- **Trade-off:** `JWT_SECRET` is now required at boot (M-9, fixed 2026-09-09); no refresh token, so a 1-day expiry is a hard logout; no server-side revocation; `passport.session()` isn't used so `serializeUser/deserializeUser` are dead code.
- **Interview Qs:** §26 exchanges on JWT vs sessions, refresh tokens, CSRF.

crypto (Node built-in) — API keys & group passwords

- **Where:** `user.generateApiKey() = randomBytes(32).toString('hex')`; `services/passwordHash.js = crypto.scrypt` for group passwords (`scrypt$salt$hash`).
- **Why scrypt over bcrypt:** no native add-on → the Vercel serverless build stays simple and the tests run without `npm install`.
- **Alternative:** `bcrypt/argon2` (native, battle-tested); a KMS for the API keys.
- **Trade-off:** the **API key itself is still plaintext at rest** — only *group* passwords are hashed.

MongoDB driver via Mongoose — no ORM/query builder beyond it. node-cron for scheduling.

- **node-cron:** `'0 * * * *'` hourly + `'30 3 * * *'` nightly rollup + an immediate run. Fine on a long-lived Render process; was **broken on serverless** (H-13) — ✅ fixed 2026-09-09: `initScheduler()` is behind `if (require.main === module)`, and `POST /api/internal/run-{notifications,rollup}` (behind `INTERNAL_CRON_SECRET`) let an external scheduler drive it.

- **Alternative triggers:** Vercel Cron, a GitHub Action on a schedule, BullMQ repeatable jobs, or Atlas Triggers hitting the internal routes.

Chart.js 4 + react-chartjs-2 + chartjs-plugin-datalabels

(Replaced 2026-10-04 by small hand-made SVG/HTML chart components; see D-32 and the update box.)

- **Where:** `Dashboard.tsx` — Line (hourly/daily hours), Pie (language breakdown), Bar (terminal success/failure, command usage, build/git trends).
- **Alternative:** Recharts (React-native components, declarative), visx/D3 (control, more code), Nivo.
- **Trade-off:** Chart.js is canvas — not accessible, not easily server-rendered, and you register scales/elements globally. Recharts would have been more idiomatic React.

Tailwind CSS 3 + a bespoke `ThemeContext`

- **Where:** utility classes for layout; `inline style={{}}` with `theme.colors.*` for anything colour-related, because there are **28 runtime-switchable themes** stored in `localStorage` and applied as CSS custom properties.
- **Trade-off:** the inline-style + theme-object pattern is verbose and repeated in every component; a proper design-token system (CSS variables + Tailwind `theme.extend`) would cut it drastically. `tailwind.config.js` `theme.extend` is empty.

Deployment: Vercel (frontend) + Render (backend) + MongoDB Atlas

- **Why:** all have free tiers; Vercel is one-click for a Vite SPA (`vercel.json` SPA rewrite); Render runs a plain Node process so `app.listen()` and `node-cron` work; Atlas is managed Mongo.
- **Trade-off:** `backend/vercel.json` exists too (serverless via `serverless-http`) — if that's the live deploy, the scheduler is broken. Render free tier sleeps after 15 min idle → cold-start latency and a missed cron window.

Not used (and you'll be asked why): Redis, Kafka/SQS, WebSockets, GraphQL, Docker, any CI.

See §26 for the rebuttals.

4. The VS Code extension — in depth

Files: `extension/src/*.ts`. Entry `extension.ts`. Built to `dist/extension.js` by `esbuild`.

4.1 Installation → activation

- Published as `CodeTrackr-ext.codetracker-vscode`. `main: ./dist/extension.js`.
- **Activation event:** `onStartupFinished` (activates shortly after VS Code finishes starting — not lazy on a command, because tracking should be passive).
- `activate(context):`
 1. `initializeTelemetry(context)` — snapshot terminal count, subscribe to open/close.
 2. Create the five trackers (`createDebugTracker`, `createTerminalTracker`, `createEditorTracker`, `createFocusTracker`, `createGitStateTracker`) and `.start(context)` each.
 3. Register 7 commands: `start`, `stop`, `flushNow`, `showStats`, `showLogs`, `setupApiKey`, `showInfo`.

4. Subscribe to `onDidChangeConfiguration` — restart the flush timer if `flushIntervalSeconds` changes; clear the auth warning if `apiKey` changes.
 5. `start(context)` — begin tracking.
 6. If no API key configured → one-time actionable warning.
- `activation.test.js` loads the real built bundle against a stubbed `vscode` and asserts every contributed command is registered, no network call happens without a key, and the payload has the four analytics blocks.

4.2 The flush loop and idle/pause state machine

State (AppState): `timer`, `lastActivityMs`, `startedMs`, `bufferedMinutes`, `lastKnownFile`, `activeTerminalCount`, `isPaused`.

`start()` subscribes to `onDidOpenTextDocument`, `onDidSaveTextDocument`, `onDidChangeActiveTextEditor`, `onDidChangeTextDocument` — all call `markActivity()` which sets `lastActivityMs = Date.now()` and, if paused, resumes (new `startedMs`, clears buffer).

`setInterval(flushIntervalSeconds * 1000)` (default **30 s**) tick:

```
idleMin = (now - lastActivityMs) / 60000
if (!isPaused && idleMin >= 2):
    if there was active time: sendActivity(activeDurationMin, lastKnownFile) // flush the tail
    isPaused = true ; startedMs = undefined ; bufferedMinutes = 0
    return
if (isPaused): return
flushIfNeeded(false)
```

`flushIfNeeded(force)` (2.3.0):

```
if (!startedMs) return
elapsedFromStartMin = (now - startedMs)/60000
idleMin = (now - lastActivityMs)/60000
if (!force && idleMin >= 2) return // idle: don't flush
totalBuffered = bufferedMinutes + elapsedFromStartMin
if (!force && totalBuffered < minFlushMinutes) return // default 2 min (was 0.5)
payload = buildPayload(round(totalBuffered*60), fileOpened)
if (!force && !payloadHasSignal(payload)) return // nothing happened → keep buffering
await sendActivity(payload)
startedMs = now ; bufferedMinutes = 0 // on success
// on throw: bufferedMinutes = totalBuffered ; startedMs = now (retry next tick)
```

4.3 What is collected, and how

Signal	Source	Tracker	Notes
Active time	<code>timer + markActivity()</code> events	<code>extension.ts</code>	buffered minutes; since 2.3.0 a signal-less flush isn't sent, trimming the old idle-<2-min L-7 skew
File name / type / project / language	<code>activeTextEditor.document</code> , <code>workspace.name</code>	<code>getFileMeta()</code>	basename only — never the path

Signal	Source	Tracker	Notes
Gross lines/chars inserted & deleted	<code>onDidChangeTextDocumentContent</code> changes	<code>EditorTracker</code>	replaces the broken <code>net-lineCount</code> delta
Churn	deletions matched against insertions ≤ 10 min old	<code>EditorTracker.consumeChurn</code>	"wrote it then deleted it"
Undo/redo	change reason <code>=== 1 / 2</code>	<code>EditorTracker</code>	
Saves, file switches, unique files	save + active-editor events	<code>EditorTracker</code>	
Read vs write time	5 s sampler: was there an edit in the last interval?	<code>EditorTracker.sampleAttention</code>	only samples while <code>window.state.focused</code>
Large inserts	insert text length > 80 chars	<code>EditorTracker</code>	count + total chars, never the text
Focused / blurred ms, blur events	<code>window.onDidChangeWindowState</code>	<code>FocusTracker</code>	removes "VS Code open but not foreground" time
Flow blocks	working stretch; closes after 2 min idle	<code>FocusTracker.tick</code>	<code>flowBlocksMs[]</code> + <code>longestBlockMs</code> ; open block left open across flushes
Commits, files changed, uncommitted count/age	<code>vscode.git</code> extension API, <code>repo.state.HEAD.commit</code>	<code>GitStateTracker</code>	counts GUI commits too; never messages/diffs
Terminal commands: total, success/fail, per-category, build/test runs, git actions, repeated failures	<code>onDidStart/EndTerminalShellExecution</code>	<code>TerminalTracker</code> + <code>analyticsAggregator</code> + <code>commandClassifier</code>	exit code → success/fail; commands sanitised (token=**) + truncated
Debug sessions	<code>debug.onDidStart/TerminalateDebugSession</code>	<code>DebugTracker</code>	folded into <code>terminalAnalytics.debuggingSessions</code>

4.4 Frequency, batching, buffering, debounce/throttle (*updated 2026-09-08 — extension 2.3.0*)

- **Timer ticks** every `flushIntervalSeconds` (default 30 s).
- **A flush is sent** only when `totalBuffered ≥ minFlushMinutes` (**default 2 min** since 2.3.0, was 0.5) **and** `payloadHasSignal(payload)` is true (there were edits / commands / commits) — otherwise the buffered time is kept and carried to the next flush. So in practice a POST every ~2 min of real coding.
- **Batched?** No HTTP batching (one `POST /api/extension/track` per flush). But the **backend merges** flushes: `planActivityWrite` floors the timestamp to a 10-minute boundary and `$inc`-upserts a `(userId, projectName, language, bucketStart)` document, so many flushes in a window = **one row**. `/track/batch` exists but is unused. `ACTIVITY_BUCKET_MS=0` restores one plain `Activity.create` per flush.
- **Buffering:** active minutes are buffered in the `state` object between ticks and across a failed flush (in memory only).
- **Debounce/throttle:** the 5 s attention sampler and the 15 s focus ticker are the only fixed intervals; edits themselves aren't debounced — they just bump `lastActivityMs` and increment counters.

4.5 Lifecycle edge cases [ACTUAL IMPLEMENTATION]

Situation	Behaviour
User idle > 2 min	Flush the tail, <code>isPaused = true</code> , stop buffering. Resume on next edit/nav.
VS Code closes	<code>deactivate()</code> does a best-effort final flushIfNeeded(true) , then stops trackers. If that POST fails, the tail is lost.
No internet / backend down	<code>axios</code> throws → buffered minutes retained in memory ; next tick retries. No disk queue — a restart loses everything un-flushed.
Invalid / rotated key	<code>verify</code> or a flush returns 401 → one-time <code>showWarningMessage</code> with "Set API Key" / "Open Dashboard". <code>authWarningShown</code> gates it to once per session.
Key "expires"	Keys don't expire. Only regeneration invalidates one.
User switches account	They regenerate on the new account and re-run Setup API Key; the old key stops working. The extension has no concept of "which account" beyond the key string.
Duplicate activity / same payload twice	The backend stores it again — no idempotency . Double flush = double count.
Clock jump	<code>duration > 3600 s</code> → the flush is skipped with a console warning. <code>duration < 1 s</code> → held for the next flush (backend 400s on falsy duration).
<code>duration === 0</code>	Backend <code>if (!duration)</code> wrongly rejects it as missing (M-4). The extension avoids sending it.

4.6 Where the API key lives locally

`vscode.workspace.getConfiguration('codetrackr').update('apiKey', key, vscode.ConfigurationTarget.Global)` → **plaintext in the user's global settings.json**. **Not** VS Code SecretStorage. `showInfo` masks it (`abcd...wxyz` (64 chars)). **[RECOMMENDED IMPROVEMENT]** move to `context.secrets` (SecretStorage), which uses the OS keychain.

4.7 Source-file map (extension)

File	Key exports / functions
<code>extension.ts</code>	<code>activate</code> , <code>deactivate</code> , <code>buildPayload</code> , <code>buildPayloadForTest</code> , <code>sendActivity</code> , <code>flushIfNeeded</code> , <code>start</code> , <code>stop</code> , <code>setupApiKey</code> , <code>showInfo</code> , <code>showStats</code>
<code>editorTracker.ts</code>	<code>EditorTracker</code> (<code>recordChange</code> , <code>consumeChurn</code> , <code>sampleAttention</code> , <code>consumeInterval</code>), <code>createEditorTracker</code>
<code>focusTracker.ts</code>	<code>FocusTracker</code> (<code>setFocused</code> , <code>noteActivity</code> , <code>tick</code> , <code>accrue</code> , <code>consumeInterval</code>), <code>createFocusTracker</code>
<code>gitStateTracker.ts</code>	<code>GitStateTracker</code> (<code>handleStateChange</code> , <code>consumeInterval</code>), <code>createGitStateTracker</code>

File	Key exports / functions
terminalTracker.ts	TerminalTracker (onExecutionStart/End, consumeInterval), createTerminalTracker
analyticsAggregator.ts	TerminalAnalyticsAggregator (recordExecution, collectRepeatedFailures, consumeInterval)
commandClassifier.ts	classifyCommand, normalizeCommand, sanitizeCommand
gitTracker.ts	detectGitAction
debugTracker.ts	DebugTracker (onSessionStart/End, onBreakpointChange, consumeInterval)

5. The unique-key / account-linking system

5.1 End to end [ACTUAL IMPLEMENTATION]

Step	Code	Detail
Generate	config/passport.js → user.generateApiKey() (models/user.js)	On first Google login. crypto.randomBytes(32).toString('hex') → 64 hex chars (256 bits of entropy).
Store	models/user.js	apiKey: { type: String, unique: true, sparse: true } — plaintext , unique index, sparse so users created before a key don't collide on null.
Show to user	routes/user.js GET /api/user/profile → Onboarding.tsx / Profile.tsx	Returned in the JSON body; copy-to-clipboard button.
Extension receives	extension.ts setupApiKey()	showInputBox({ password:true }), >= 16 chars validation, saved to global config.
Extension sends	extension.ts sendActivity()	headers: { 'x-api-key': apiKey } on every POST /api/extension/track.
Backend verifies	middleware/auth.js verifyApiKey	apiKey = req.headers['x-api-key'].trim(); User.findOne({ apiKey }); !user → 401; else req.user = user.
Attribution	routes/extension.js	Activity.userId = req.user._id.toString().
Rotate	routes/user.js POST /api/user/regenerate-api-key	Overwrites apiKey; old key dead immediately.

Uniqueness guarantee: 256-bit random + a unique index. Collision probability is cryptographically negligible; the index would reject a dup on write anyway.

5.2 Is this actually "just an identifier"? — the discussion an interviewer wants

No. Distinguish the roles:

Role	Does the key play it?	Why it matters
Identifier	Yes — resolves to exactly one user.	A pure identifier (like a username or a public user id) is <i>safe to expose</i> .
Authenticator	Yes — possession alone authorises writes; there's no second factor.	This is what makes it a <i>credential</i> , not an id.
Bearer token	Yes — sent on every request, no proof-of-possession, no signature.	Anyone who observes it can replay it.
Pairing token	Yes — binds one extension install to one account.	But it never "completes" a pairing; it stays live forever.
Secret	It's <i>treated</i> as one (masked in UI, <code>password:true</code> input) but stored and compared in plaintext .	If the DB leaks, every key leaks in usable form.
Scoped	No — full ingest authority, no per-resource scope.	Can't issue a "write-only, this-device" key.
Expiring	No.	A leaked key is valid until the user manually rotates.

Verdict to say out loud: "It's functionally an unscoped, non-expiring API token stored in plaintext. That's a defensible MVP choice — it's one `findOne`, no token minting, works offline — but I'd call it a credential in a review, not an identifier, and I know how I'd harden it."

5.3 Attack scenarios [ACTUAL IMPLEMENTATION risk]

1. **Key theft → leaderboard fraud.** With a stolen key, `curl POST /api/extension/track` with `duration: 3600`, `language: "TypeScript"` in a loop → the victim's coding hours (and the global leaderboard) are corrupted. No rate limit, no anomaly check, no idempotency. *Bounded by:* the attacker still can't read the victim's dashboard (needs the JWT).
2. **DB compromise → mass key leak.** Keys are plaintext, so a read of `users` yields working credentials for everyone.
3. **Accidental exposure.** The key is shown in the dashboard and pasted into `settings.json`, which people commit to dotfiles repos. It's also in `GET /api/user/profile` responses in browser history / logs.
4. **No brute force needed** — 256 bits — but also **no logout** if someone tried.
5. **Self-inflicted inflation.** A user can point their own key at `curl` and cheat the leaderboard directly. Cheating is trivial and undetected (see §26).

5.4 How to redesign it [RECOMMENDED IMPROVEMENT]

- **Hash at rest.** Store `sha256(key)` (fast, keys are high-entropy so a slow KDF isn't required) or `script`. Issue as `ct_<keyId>_<secret>`; look up by indexed `keyId`, compare the secret in constant time. DB leak no longer yields usable keys.
- **Multiple named keys per user**, each independently revocable ("Work laptop", "Desktop").
- **Rotation with a grace window** — old key valid for 24 h after rotation so tracking doesn't silently break.
- **Scope + metadata** — `scope: ['ingest']`, `lastUsedAt`, `createdAt`, `userAgent`.

- **Better still:** the dashboard mints a **short-lived signed ingest token** (JWT, 24 h, aud: 'ingest') that the extension refreshes; or an **OAuth 2.0 device-authorization flow** so the extension never handles a long-lived secret.
- **Defence in depth on ingest:** rate-limit per key, reject implausible `duration`, require a client-generated idempotency key, flag statistical anomalies.

6. Database design (MongoDB / Mongoose)

6.1 Collections, purpose, structure

`activities` — the only high-volume collection

```
{
  userId: String,           // hex of users._id — NOT an ObjectId ref
  fileName: String,        // required, basename only
  fileType, projectName, language: String,
  duration: Number,        // SECONDS ← $inc of REAL measured seconds; every reader /3600
  linesAdded, linesRemoved: Number, // gross counts, $inc-accumulated per bucket
  timestamp: Date,         // == bucketStart (the 10-min window start)
  bucketStart: Date,       // 10-min-floored; present only on bucketed docs (2026-09-08)
  files: [String],         // de-duped basenames merged into this bucket
  flushCount: Number,      // how many flushes merged in (default 1)
  // (`date` field REMOVED 2026-09-08 — nothing read it; index dropped)
  terminalAnalytics: { totalCommands, successfulCommands, failedCommands, successRate,
                      buildRuns, testRuns, successfulBuilds, failedBuilds, buildSuccessRate,
                      debuggingSessions, commandUsage:
                        {git,npm,node,python,docker,gcc,java,pip,misc},
                      gitActivity:{commits,pushes,pulls,checkouts,merges,clones},
                      repeatedFailedCommands:[{command,count}], lastCommand, lastCommandTimestamp
                    },
  editorAnalytics: { charsInserted, charsDeleted, linesInserted, linesDeleted, churnLines,
                    undoCount, redoCount, saveCount, fileSwitches, uniqueFiles,
                    readMs, writeMs, largeInsertCount, largeInsertChars },
  focusAnalytics: { focusedMs, blurredMs, blurEvents, flowBlocksMs:[Number], longestBlockMs },
  gitAnalytics: { commits, filesChanged, uncommittedFiles, uncommittedAgeMs }
} // { timestamps: true } adds createdAt / updatedAt
```

- **Purpose:** one merged record per 10-minute `(user, project, language)` window. `duration` is `$inc`-accumulated from real measured seconds — **totals unchanged** vs the old per-flush model; only time-of-day resolution is now the 10-minute grid.
- **Write:** atomic `Activity.findOneAndUpdate({...key, bucketStart}, {$inc, $max, $push $slice:-200, $addToSet files, $setOnInsert}, {upsert:true, setDefaultsOnInsert:false})`, keyed by a partial-unique index `{userId, projectName, language, bucketStart}`. `11000` on the upsert insert → retry once as a plain update.
- **Relationships:** `userId` → `users._id` (as a string; no populate).
- **Was:** one doc per flush → ~60–120 docs/user/active-hour, unbounded. **Now:** ~6–12 docs/user/active-hour. Sparse sub-docs (only non-zero leaves written). `date` field + its index removed. 400-day TTL on `createdAt`. A `dailysummaries` nightly rollup exists.
- **Still to do:** repoint the all-time reads (leaderboard, `/summary`, `metrics >90d`) at `dailysummaries` and tighten the TTL — bundle with a `UserStats` rollup; migrate `userId` to `ObjectId`.

`dailysummaries`

`{ userId, day (YYYY-MM-DD UTC), totalSeconds, totalLinesAdded/Removed, flushCount, bucketCount, languages:[{language,seconds}], projects:[String], editor/terminal/git aggregates, focus{ } }`, unique `{userId,day}`. Written nightly by `scripts/rollup-daily.js` / the `initScheduler` cron from raw activities.

Not yet consumed by any read — it's infrastructure for the future all-time-read cutover.

`users`

`googleId` (unique), `email` (unique), `name`, `profilePictureUrl`, `apiKey` (unique, sparse, plaintext), `lastLogin`, `isFirstLogin`. Purpose: identity + the ingest credential.

`groups / groupmembers`

`groups`: `name`, `description`, `visibility`, `password` (`select:false`, script hash), `createdBy` (`ObjectId→User`).
`groupmembers`: `{ groupId, userId, joinedAt }` with **unique compound index** `{groupId:1,userId:1}` — a real join table. This is the correct many-to-many modelling and the compound unique index is the one hard concurrency guard.

`goals`

`userId` (`ObjectId`), `title`, `description`, `targetHours` (min 1), `techStack` (`String`), `deadline`, `status` (`in-progress/completed`, default `in-progress`), `reminderSent`. `PATCH /:goalId/complete + /reopen` set the status (added 2026-09-10). **Before that no route ever did** — only the seed script — so estimation calibration could never populate. Progress is computed on demand, not stored.

`teams`

`name`, `description`, `createdBy`, `members`: [`ObjectId`] **embedded**. Backend routes exist; **no frontend route** — orphaned. A deliberately different modelling choice from `groups` (embedded array vs join table) — good talking point on embedding vs referencing.

`notifications`

`userId`, `goalId`, `type` (enum incl. `goal_completed` which is never produced), `title`, `message`, `read`. Written by `notificationScheduler`.

6.2 Indexes [ACTUAL IMPLEMENTATION — updated 2026-09-08]

On `activities`: `{userId:1}`, `{userId:1,timestamp:-1}` (added — the range queries every read does), `{userId:1,projectName:1}`, `{userId:1,language:1}`, **partial-unique** `{userId:1,projectName:1,language:1,bucketStart:1}` (`partialFilterExpression`: `{bucketStart:{$exists:true}}`) — race-safe bucket merge, ignores legacy per-flush docs), **400-day TTL on** `{createdAt:1}`. The old `{userId:1,date:-1}` index was **dropped** (nothing queried date; `scripts/migrate-drop-date.js --apply` removes it + the field). `{groupId:1,userId:1}` unique on `groupmembers`; unique on `users.googleId/email/apiKey`; `{userId:1,day:1}` unique on `dailysummaries`.

Still weak:

- No index supporting the leaderboard's collection-wide `$group` (there's no good one — it's a full scan by nature; the `UserStats` rollup is the fix).

6.3 SQL vs MongoDB — the full answer

Why Mongo fits here: append-only documents, schema evolution without migrations, per-user-window access pattern, no hot-path joins, free-tier managed hosting (Atlas), team familiarity, and a single model file per entity.

When Postgres would be better:

- **Relational integrity:** `groupmembers`, `teams.members`, goal/notification ownership — foreign keys and `ON DELETE CASCADE` would remove the "filter out null groups if deleted" defensive code in `groups.js`.
- **The leaderboard:** `SELECT user_id, SUM(duration) ... GROUP BY user_id ORDER BY 2 DESC LIMIT 50` with a covering index is $O(\text{index scan})$, not "load the whole table into Node".
- **Transactions:** `team.members.push()` + `save()` is a read-modify-write with a lost-update window; SQL `INSERT ... ON CONFLICT DO NOTHING` on a join table is atomic.
- **Ad-hoc analytics:** window functions, `GROUP BY GROUPING SETS`, percentiles.

When a time-series DB (Timescale/Influx) would be better still: the activity stream is literally time-series — automatic partitioning by time, continuous aggregates (materialised rollups), retention policies. That's the "right" store for activities at scale.

6.4 Consistency, races, atomicity

- **No transactions.** Every write is a single document op, which Mongo makes atomic — so ingest is fine.
- **Double-join race:** two concurrent `POST /:groupId/join` → the second hits the unique compound index → duplicate-key error, which the handler now detects (`error.code === 11000`) and surfaces as a **409** (fixed 2026-09-09; was a 500).
- **Last-member-leaves race:** two members leave simultaneously; both see `remainingMembers` briefly and one deletes the group — benign but sloppy; a transaction or a `findOneAndDelete` guard would tidy it.
- `team.members.push` **lost update:** concurrent adds can clobber each other. Fix: `$addToSet`.
- **Leaderboard:** recomputed per request, so always consistent, never stale, never cached.

7. Backend & API architecture

7.1 Endpoint table

Method	Endpoint	Purpose	Input	Auth	Processing	Response
GET	<code>/</code>	liveness ping	—	—	—	<code>200</code> <code>{status:'ok'}</code>
GET	<code>/health</code>	readiness	—	—	<code>mongoose.connection.readyState</code>	<code>200</code> <code>{status:'ok',db:true} /</code> <code>503</code> <code>{status:'degraded'}</code> (added 2026-09-09)

Method	Endpoint	Purpose	Input	Auth	Processing	Response
POST	/api/extension/track	ingest one flush	body: fileName, language, duration(s), timestamp?, analytics sub-objects	verifyApiKey (x-api-key) + IP rate-limit (120/min, added 2026-09-09)	validate → normalise → planActivity Write → 10-min bucket \$inc upsert (or Activity.create if ACTIVITY_BUCKET_MS=0)	201 {success, activity: {...}}
POST	/api/extension/track/batch	ingest many	{ activities: [...] }	verifyApiKey	map+normalise → Activity.insertMany	201 {success, count}
GET	/api/extension/verify	key check	—	verifyApiKey	—	200 {success, user: {id,name,email}}
GET	/api/analytics/:userId?timezone=	today hourly + 7d totals	tz offset (min)	isAuthenticated + ownership	Activity.find(7d) → JS reduce; computeStreak (\$group)	{ totalHours, projectCount, totalLinesAdded, streakDays, dailyActivity[24], languageBreakdown[], terminalSummary, *Timeline[] }
GET	/api/analytics/weekly/:userId?timezone=	7-day daily	tz	isAuthenticated + ownership	Activity.find(7d) → JS reduce	daily breakdown + language + terminal
GET	/api/analytics/timeslot/:userId?start=&end=&timezone=	2h drill-down	start/end hour, tz	isAuthenticated + ownership	Activity.find(window) → 10-min slots	{ totalMinutes, totalLines, fileCount, productivity, tenMinuteSlots[12], languages[] }

Method	Endpoint	Purpose	Input	Auth	Processing	Response
GET	/api/analytics/summary/:userId	daily + per-stack totals	—	isAuthenticated + ownership	2× Activity.aggregate \$group	{ dailyTotals[], stackTotals[] }
GET	/api/leaderboard	global ranking	—	isAuthenticated	User.find({}) + Activity.aggregate(all) → merge/sort/score in Node	[{ rank, userId, name, email, totalHours, ... , speed, quality, engagement, impact, overall }]
GET	/api/metrics?days=&timezone=	derived insights	days (1–365), tz	isAuthenticated (no :userId)	4× Activity.aggregate → metricsDerive	{ success, metrics: {...11 fields...} }
POST	/api/goals/create	new goal	title, description, targetHours, techStack, deadline	isAuthenticated	Goal.create (userId from session)	201 goal
GET	/api/goals	my goals	—	isAuthenticated	Goal.find({userId})	[goal]
GET	/api/goals/:goalId/progress	goal progress	—	isAuthenticated + owner scope	Goal.findOne({_id,userId}) + Activity.aggregate (language or project matches techStack, within the goal's lifetime)	{ goal, currentHours , progress }
PATCH	/api/goals/:goalId/complete /reopen	complete / reopen a goal	—	isAuthenticated + owner scope	sets status + completedAt (2026-09-10, M-17)	the goal
POST	/api/groups/create	new group	groupName, groupDescription, visibility, password?	isAuthenticated	hash pw → Group.save → GroupMember.save (creator)	201 {group} (no password)

Method	Endpoint	Purpose	Input	Auth	Processing	Response
GET	/api/groups/ my-groups	member of	—	isAuthenticated	GroupMember. find({userId}).populate(groupId)	{groups:[]}
GET	/api/groups/ discover? search=	not a member of	search?	isAuthenticated	Group.find({ _id: {\$nin:joined }, name: containsRegex(search)}). limit(100) — escaped (H-16)	{groups:[]}
GET	/api/groups/ :groupId/details	members + leaderboard	—	isAuthenticated + membership	GroupMember. find().populate + Activity.aggregate({\$in: memberIds})	{group, members[], leaderboard[]}
POST	/api/groups/ :groupId/join	join	password?	isAuthenticated	verify pw (private) → GroupMember. save	{success, group}
POST	/api/groups/ :groupId/leave	leave	—	isAuthenticated	GroupMember. findOneAndDelete; delete group if empty	{success, message}
GET	/api/notifications · /unread-count	list / count	—	isAuthenticated	Notification. find/countDocuments({userId})	list (≤50) / {count}
PATCH	/api/notifications/:id/read · /mark-all-read	mark read	—	isAuthenticated	findOneAndUpdate({_id,userId}) / updateMany	{notification} / {message}
DELETE	/api/notifications/:id	delete	—	isAuthenticated	findOneAndDelete({_id,userId})	{message}
POST	/api/teams/create · GET /api/teams · GET /api/teams/:teamId · POST /api/teams/:teamId/members	teams	—	isAuthenticated (+ membership / admin)	Team CRUD	team objects — no UI

Method	Endpoint	Purpose	Input	Auth	Processing	Response
GET	/auth/google · /auth/google /callback	OAuth	—	—	passport → sign JWT → cookie → redirect	redirect
GET	/auth/current-user	decode cookie	—	—	jwt.verify	{user} / 401
POST	/auth/logout	clear cookie	—	—	res.clearCookie	{success}
GET	/api/user/profile	my profile + apiKey	—	isAuthenticated	User.findById	{success, user:{..., apiKey}}
POST	/api/user/regenerate-api-key	rotate key	—	isAuthenticated	generateApiKey + save	{success, apiKey}
POST	/api/user/complete-onboarding	flip flag	—	isAuthenticated	isFirstLogin = false	{success}

7.2 Middleware pipeline

app.js: cors(allowlist, credentials:true) → helmet() → express.json() → cookieParser() → passport.initialize() → rateLimit on /auth (50/15min) and /api/extension (120/min), skipped under NODE_ENV=test → routers (added 2026-09-09). Still **no** validator (M-4) and **no** central error handler (M-10) as of this section — each route wraps its body in try/catch and calls next(err); a central (err, req, res, next) handler (registered after the routers) logs the full error with a correlation id and returns { error, id } — no err.message leak (M-10, fixed 2026-09-09). try/catch wrappers kept for now.

7.3 Status codes actually used

200 reads, 201 creates, 400 missing fields / bad body, 401 unauth/invalid-key/expired-JWT, 403 ownership/membership failure, 404 not found, 500 anything thrown. double-join now returns 409 (fixed 2026-09-09); no 422; /auth and /api/extension are rate-limited (429) as of 2026-09-09, other routes are not.

7.4 API design weaknesses

- GET endpoints still take :userId in the path even though it's verified against the session — kept for "one release of backward compatibility" (H-1 note); cleaner to drop it.
- POST /api/user/regenerate-api-key and complete-onboarding are POST with no body and no CSRF token.
- Error bodies are generic { error, id } since 2026-09-09 (central handler); a few routes still keep deliberate 4xx bodies with a fixed string.
- No pagination anywhere (notifications is hard-capped at 50; leaderboard/groups unbounded).
- No API versioning.
- /track uses !duration so 0 is rejected.

8. Frontend architecture

8.1 Structure

- `main.tsx` → `<StrictMode><ThemeProvider><App/></ThemeProvider>`.
- `App.tsx` — `BrowserRouter`, auth gate (GET `/api/user/profile` on mount), nav shell, `<Routes>`. Unauthenticated users get only `/login`.
- Pages: Login, Onboarding, Dashboard, Insights, Leaderboard, Goals, Groups, Profile. (Teams exists, is not routed.)
- Components: `NotificationPanel`, `ThemeSelector`, `GradientText`, `TextType`, `ElectricBorder`, and heavy decorative WebGL/canvas pieces (Orb via OGL, Hyperspeed, LetterGlitch, `TargetCursor`).

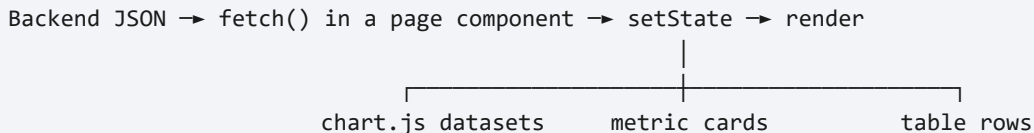
8.2 State management [ACTUAL IMPLEMENTATION]

- **No data-state library.** `useState` per page + **prop-drilling** the `user` object into `Dashboard` and `Groups`.
- **The only Context** is `ThemeContext` (theme name + palette + `setTheme`, persisted to `localStorage`).
- **Auth state** lives in `App.tsx` (`user` / `loading`), derived from one profile fetch.
- **Server state** is refetched on every navigation with `cache: 'no-cache'` + `Pragma` headers. `@tanstack/react-query` is a dependency and **completely unused** (M-12).
- **Local UI state** examples: `Dashboard` `viewMode`, `selectedTimeSlot`; `Groups` `activeTab`, modal flags; `Insights` `days`.

8.3 React concepts actually used (and the questions they invite)

Concept	Where	Interview Q
<code>useEffect([])</code> for data on mount	every page	"What runs twice in <code>StrictMode</code> and does it matter here?" (fetches — idempotent GETs, so fine)
<code>useEffect([dep])</code> refetch	<code>Dashboard</code> <code>[viewMode]</code> , <code>Insights</code> <code>[fetchMetrics]</code>	" <code>Dashboard</code> fires 3 requests on mount, one redundant — why?" (M-11: <code>[]</code> + <code>[viewMode]</code> both call <code>fetchAnalytics</code>)
<code>useCallback</code>	<code>fetchAnalytics</code> , <code>fetchMetrics</code>	"Why memoise these?" (stable identity for the effect dep)
<code>useRef</code>	<code>NotificationPanel</code> <code>panelRef</code> (click-outside)	
<code>useContext</code> custom hook	<code>useTheme()</code> throws if outside provider	"Why throw?" (fail fast on a wiring bug)
Conditional rendering	loading / error / empty states everywhere	
Lists + keys	leaderboard rows keyed by <code>userId</code> , groups by <code>_id</code>	
Controlled inputs	every form (<code>Goals</code> , <code>Groups</code> , <code>Teams</code>)	
Prop-drilling	<code>user</code> → <code>Dashboard/Groups</code>	"When would you lift this to Context / a store?"
Derived state in render	<code>Leaderboard</code> team average, <code>Dashboard</code> chart datasets	"Should these be <code>useMemo</code> ?" (cheap enough not to)

8.4 Data flow (frontend)



No API client abstraction — each component calls `fetch(\${API_URL}/...`, {credentials:'include'})` directly. API_URL from config.ts`.`

8.5 Loading / error / empty states

Consistently handled: each page has a `loading` boolean → spinner text; failed fetches `console.error` and often leave the page in its empty state; `Insights` has an explicit error card with "Try again"; `Leaderboard/Groups/Dashboard` render "No data yet" empties. `Groups` uses `alert()` for errors (crude but present).

8.6 Known frontend problems [ACTUAL IMPLEMENTATION]

1. `npm run build` — **green 2026-09-09** — was `tsc -b` → 29 errors (16 in `Goals.tsx`, 5 `TextType.tsx`, 3 each `Groups/Dashboard`, 1 each `Teams/Profile`); 2 are real (`string not assignable to never`), the rest unused imports/vars (M-13).
2. **Dashboard "Repeated Failures"** renders `repeatedFailuresDaily` / `repeatedFailuresWeekly` — **hardcoded arrays** — instead of `terminalSummary.repeatedFailedCommands`, which the backend does compute.
3. **Goals.tsx to-dos** (`addTodo`/`toggleTodo`/`deleteTodo`) mutate React state only — never persisted, no API. No goal completion / delete / progress-bar UI; the `/:goalId/progress` endpoint is never called.
4. ~~`NotificationPanel` polling `useEffect` closes over a state `isOpen` (L-1)~~ — fixed 2026-09-12; the interval reads `isOpenRef.current`, so an open panel refreshes again.
5. `Teams.tsx` is dead (no route).
6. No client caching / dedup — every nav refetches.

9. Analytics processing

9.1 Where it happens [ACTUAL IMPLEMENTATION]

Almost entirely **in Node, not MongoDB** (`routes/analytics.js`): `Activity.find(...)` then `.filter` / `.reduce` / `Map`. Exceptions: `computeStreak` and `/summary/:userId` use real `$group` pipelines; `/api/metrics` uses `$group` throughout.

9.2 The daily endpoint, step by step

1. `Activity.find({ userId, timestamp: { $gte: sevenDaysAgo } })` — **7 days of docs to render 1 day** (M-1).
2. Compute user-local midnight from the `?timezone=` offset (minutes, `Date.getTimezoneOffset()` semantics).
3. `todayActivities = activities.filter(in [startOfToday, endOfToday])`.
4. Totals: $\Sigma \text{duration} / 3600 \rightarrow \text{hours}$; `new Set(projectName)` → project count; $\Sigma \text{linesAdded}$.

5. `computeStreak(userId, tzOffset)` — separate 90-day `$group` by local-day string, Set membership, walk backward from today (or yesterday, so a not-yet-started day doesn't break the streak).
6. Hourly map (24 buckets) of hours; language map → sorted breakdown.
7. `buildTerminalSummary(todayActivities)` — sum every terminal counter, merge `commandUsage`, top-5 repeated failures, recompute `successRate` / `buildSuccessRate`.
8. Hourly terminal / build / git timelines (24 buckets each).

9.3 Timezone handling

The client sends `new Date().getTimezoneOffset()` (minutes, **negative east of UTC**) as `?timezone=`. `localDayInfo(instant, offset)` subtracts `offset*60000` and takes the ISO date. The weekly endpoint historically **ignored** the offset (M-2) — now fixed.

9.4 Correctness history (all in `IMPROVEMENT_PLAN.md`, all fixed)

- **H-3:** goal progress was 60× overstated — `duration` (seconds) was treated as minutes.
- **H-4:** `/summary/:userId` always returned zero (bad `$match` type).
- **H-5:** `date` was written as the ingest day, so backdated flushes landed on "today".
- **H-6:** streak was wrong three ways — seeded to 1 with no recency check, capped at 7 days, no timezone bucketing.

9.5 Complexity

For a user with `N` activity docs in the window: `find` is $O(N)$ docs transferred + parsed; JS aggregation is $O(N)$; memory $O(N)$ (all docs resident). Streak: $O(N_{90})$ where `N90` is 90-day docs. The dominant cost is **transferring and deserialising every document** rather than letting Mongo aggregate — which is exactly why M-1 matters at scale.

10. Leaderboard

10.1 What determines rank [ACTUAL IMPLEMENTATION]

`totalHours` = $\sum \text{duration} / 3600$ over **all time**, descending. Ties → array order (stable sort → effectively insertion order from the merge). `rank` = `index + 1`.

10.2 How it's computed

`routes/leaderboard.js`:

1. `User.find({}).select('_id name email profilePictureUrl').lean()` — **all users**.
2. `Activity.aggregate` over the **entire collection** (or an optional `?days=` window, ≤ 400):
 - `$match { duration: { $gte: 0 } }` — corrupt negative rows can't subtract from a real total.
 - `$group` by the String `userId`: `$sum duration`, `$sum linesAdded/Removed`, `$addToSet projectName`, **real commits** (`$ifNull` of `gitAnalytics.commits`, falling back to `terminalAnalytics.gitActivity.commits` — never both), and `flushes` (`$ifNull($flushCount, 1)`).
 - `$addFields: totalHours`, `projectCount = $size(projects)`, `codeChanges`, `netCodeChanges`.
3. Build a `userId → stats` map in Node; map all users onto it (users with no activity get zeros).
4. Sort by `totalHours` desc; assign `rank`.

5. **Relative scoring:** `maxHours`, `maxChanges`, `maxCommits` via `maxOf()` (a fold, floored at 1). Each user's `speed/quality/engagement/impact = score(value, max) = ratio*5` clamped to **[0, 5]** — `impact` uses `max(0, netCodeChanges)`; `overall` = their average; `commitScore = score(commits, 20)`.

10.3 Properties & problems

- **Dynamic, never cached** — recomputed every request → always fresh, always expensive.
- **No time window by default** — cost grows with total activity **forever** (optional `?days=` bounds it).
- **No pagination, no \$limit** — the entire ranked list is returned.
- **Relative scores are unstable** — everyone's score shifts when the top user codes.
- **\$addToSet on every project name** across all activity — memory-heavy in the pipeline.
- **Privacy:** every row includes `email`.
- **Group leaderboard** (`/groups/:id/details`) — same pattern, scoped to member IDs, all-time, no pagination (H-8).
- **Fixed 2026-09-10:** "commits" was `activityCount` — flush count — not git commits (H-17); `impact` could go negative and drag `overall` below zero (M-18); `Math.max(...spread)` threw `RangeError` past ~100k users (H-18); the group route's `Promise.all` over a non-async map is gone.

10.4 Complexity

$O(A + U)$ per request where A = total activity documents ever written, U = total users; plus $O(U \log U)$ sort; all in application memory. On Render's request timeout / Vercel's serverless limit this fails "long before the user count becomes interesting" (H-7).

10.5 "Optimise for 10M users" [RECOMMENDED IMPROVEMENT]

1. **UserStats rollup collection** — `{ userId, totalSeconds, totalLinesAdded, projectCount, activityCount, updatedAt }`, incremented on ingest with `$inc` (or by a scheduled job). Leaderboard = `UserStats.find().sort({totalSeconds:-1}).limit(50)` — **O(index scan)**, reads U docs not A .
2. **Time-windowed** rollups (`daily_stats` keyed `{userId, day}`) for "this week/month" boards; sum the window.
3. **Cache** the top-N list in Redis with a short TTL; recompute on a cron or on write.
4. **Paginate / cursor** the full board.
5. **Rank at read time** from the sorted rollup, or maintain a Redis **sorted set** (`ZADD leaderboard <score> <userId>`, `ZREVRANGE` for a page, `ZREVRANK` for "your rank") — $O(\log N)$ updates, $O(\log N + \text{page})$ reads, the classic answer.
6. **Anti-cheat** before any of this matters (see §26).

11. Groups — the core feature

Why it's the heart of the product: the whole project exists so a friend group can run **friendly competition** — a contest week, or an ongoing daily-practice streak. You make a group, everyone joins, and because every member's editor is tracked automatically, the group page ranks who actually did the work. The intent was also "see how many errors each person hit" — the extension records per-person `failedCommands` / `failedBuilds` / `repeatedFailedCommands`, and since 2026-09-10 the group leaderboard shows it: each member's **hours, lines, commits, failed commands and failed builds**, with failure rates (`null` → "—" when nothing ran, so "never failed" and "never ran" don't look the same). It is still ranked by coding hours.

11.1 Model [ACTUAL IMPLEMENTATION]

`groups` (metadata + bcrypt-hashed `password`, `select:false`) + `groupmembers` join table (`{groupId,userId}` unique compound). Membership is **not** an embedded array (unlike `teams`), which is the right call for a growing many-to-many.

11.2 Lifecycle

- **Create** (POST `/groups/create`): validate name/description/visibility; private → require a password, `hashPassword(password)` (bcrypt); `Group.save`; auto-add creator as a `GroupMember`; response strips `password`.
- **Discover** (GET `/groups/discover`): `Group.find({ _id: { $nin: joinedGroupIds } })`, optionally `name: containsRegex(search)` — escaped, trimmed, ≤ 128 chars (H-16) — and `.limit(100)`.
- **Join** (POST `/groups/:id/join`): `Group.findById().select('+password')`; reject if already a member; private → `verifyPassword(password, group.password)` (401 on mismatch); **opportunistic migration** — if the stored value isn't a hash, rehash it now; `GroupMember.save`. Public group → `handleJoinClick` in the UI POSTs an empty body and the backend skips the password check.
- **Details** (GET `/groups/:id/details`): **membership check first** (`GroupMember.findOne` → 403 if not a member); then members list + a group leaderboard (all-time `Activity.aggregate` over member IDs).
- **Leave** (POST `/groups/:id/leave`): `GroupMember.findOneAndDelete`; if `countDocuments({groupId}) === 0` → `Group.findByIdAndDelete` (group self-destructs when empty).

11.3 Authorization & concurrency issues

- **Ownership**: only membership is checked. There's no "admin" concept for groups — `createdBy` is stored but never used to gate anything. Any member can view details; there's no kick/rename/delete-by-owner, no transfer.
- **Double-join race**: unique index catches it → **409** (the handler detects `error.code === 11000`, fixed 2026-09-09).
- **Password brute force**: no rate limit on `/join` → a private group's password can be guessed offline-speed via the endpoint.
- **Empty-group deletion race**: two `leave`s at once → both compute `remainingMembers`, one deletes; harmless but not transactional.
- **Enumeration**: `discover` lists every non-joined group including private ones (name + description + creator), so private groups aren't hidden, only password-gated.

11.4 Interview questions this raises

"How do you prevent a user joining twice?" (unique index) · "What status code should a duplicate join return?" (409) · "How would you add group admins?" (a `role` column on `groupmembers`, gate mutations on `role === 'owner'`) · "Private group password vs per-user invites — which is better and why?" (invites: revocable, auditable, no shared secret) · "How would you rate-limit join attempts?" (per-user + per-group counter, exponential backoff).

"You said the point was comparing errors — how did you add that to the group view?"

"The data was already there — each member's activity carries `failedCommands`, `totalCommands`, `failedBuilds` and `buildRuns`. The group-details endpoint already `$grouped` Activity by member for hours and lines, so I extended that same pipeline with `$sum` of those counters plus real commits,

computed per-member failure rates, and added Commits / Cmd fails / Build fails columns. A rate is `null` when nothing ran, so the table shows '—' rather than a misleading 0%. Read-path only, no schema change. Next would be a 'most-improved success rate this week' badge."

"A contest week — how do you scope the leaderboard to just that week?"

"Right now the group leaderboard is all-time (`Activity.aggregate` over member IDs, no window). I'd add a `?from=&to=` to `/groups/:id/details` and a `$match` on timestamp; a group could store a `contestStart/contestEnd`. The 10-minute bucketing doesn't change this — buckets are stamped `bucketStart` so a time-range `$match` still works."

12. Insights / ML system

12.1 The honest classification [ACTUAL IMPLEMENTATION]

It is deterministic descriptive statistics, not machine learning. No model, no training, no inference, no Python, no LLM, no external AI API. Everything is pure JavaScript in `services/metricsDerive.js` (unit-tested, dependency-free) fed by aggregations in `services/metricsService.js`.

12.2 The pipeline

```
GET /api/metrics?days=30&timezone=<offset>
→ isAuthenticated (identity = session only, no :userId)
→ buildMetrics(userId, {days, timezoneOffset})
  (A) Activity.aggregate $group over {userId, timestamp ≥ now-days}:
      focusedMs, flowBlocksMs (pushed+flattened), churnLines, linesInserted,
      readMs, writeMs, fileSwitches, commits, totalSeconds
  (B) $group by local day → daily minutes[]
  (C) $group by local hour → [{hour, minutes, commits, linesInserted, churnLines}]
  (D) buildGoalPairs: Goal.find({status:'completed'}) → Activity.aggregate by language
      → [{estimatedHours, actualHours}]
→ metricsDerive:
  deepWorkRatio      = Σ(block ≥ 25min) / Σ(all blocks)                ∈ [0,1]
                      (÷ focusedMs mixed two clocks and could exceed 1 – fixed 2026-09-10)
  flowBlockStats     = { medianMs, longestMs, deepBlockCount, blockCount, totalMs }
  volumeStability    = clamp(1 - MAD/median, 0, 1)                    alias: consistencyIndex
  activeDaysRatio    = activeDays / observedDays                     ← real cadence (span, not count)
  qualityStreak      = consecutive days containing a ≥25min block
  truePeakWindow     = argmax over 2h windows of Σ minutes×(1-churnRatio), ≥3 days
  estimationCalibration = median(actual/estimated) + range, from 1 completed goal
  + churnRatio, comprehensionLoad, contextSwitchesPerHour, interruptionsPerHour
  + meta[metric].{confidence, sampleSize, unit, baseline?, delta?}
→ res.json({ success, metrics })
```

12.3 Every metric, defined exactly

Metric	Formula (as coded)	Interpretation	Failure mode
deepWorkRatio	$\Sigma \text{ blocks} \geq 25 \text{ min} \div \Sigma \text{ all blocks}$, rounded 2dp	fraction of <i>flow-block</i> time spent in long stretches	0 if no blocks. Divided by <code>totalFocusedMs</code> until 2026-09-10 — a different clock, so it could exceed 1
flowBlocks	median / longest / deep-count / count / <code>totalMs</code> of <code>flowBlocksMs</code>	shape of sessions	zeros on empty
volumeStability	<code>clamp(1 - MAD/median, 0, 1)</code> of daily minutes	steadiness of <i>how much</i> you code on the days you code	0 if no days or <code>median</code> ≤ 0 . Was $1 - \sigma/\mu$; the mean/ σ pair is dominated by one outlier day
activeDaysRatio	<code>activeDays</code> $\div$ <code>observedDays</code> , where <code>observedDays</code> spans your first active day in the window through today, capped at the window	the actual <i>cadence</i> metric — the daily <code>\$group</code> emits no zero-days, so <code>volumeStability</code> never saw them	0 on an empty window. (Until 2026-09-12 <code>observedDays</code> was <code>min(window, activeDays)</code> , which made the ratio 1 for everyone — M-22.)
consistencyIndex	alias of <code>volumeStability</code> (back-compat for older dashboard builds)	—	—
truePeakWindow	2-hour window maximising $\Sigma \text{ minutes} \times (1 - \text{churnRatio})$ ("surviving minutes"), eligible only at ≥ 3 distinct days	most <i>productive</i> window (vs busiest)	null if no window clears the day floor
estimationCalibration	<code>median(actual/estimated)</code> over completed goals with <code>estimated > 0</code> , plus <code>minFactor/maxFactor</code>	>1 = you underestimate	null if no usable pair. Usable from one goal; was a mean requiring ≥ 2
churnRatio	<code>churnLines</code> / <code>linesInserted</code>	rework fraction	0 if <code>linesInserted</code> = 0
comprehensionLoad	<code>readMs</code> / (<code>readMs</code> + <code>writeMs</code>)	share of time reading	0 if no attention data
contextSwitchesPerHour	<code>fileSwitches</code> / <code>focusedHours</code>	fragmentation	0 if <code>focusedHours</code> = 0

12.3b The rules layer — "What stands out" [ACTUAL IMPLEMENTATION, 2026-09-10]

`services/rulesEngine.js` reads the finished metrics object and returns `{ findings, skipped, totalFindings }`, sent as `insights` beside `metrics`. 13 declarative rules — churn spike against your own baseline, fragmented focus (> 30 file switches per focused hour), frequent interruptions, deep work strong / scarce, peak window, low cadence, erratic volume, a ≥ 3 -day streak, reading-heavy, estimation under / accurate. Each declares `requires`; if any required metric is missing or `insufficient`, the rule is **skipped and reported**, never evaluated on a zero — checked at startup, because `confidence !== 'insufficient'` is true for a

missing entry. Findings sort warning → info → positive, cap at 6, and carry the `evidence` that fired them. Verified on real data: a 30-day window with 6 sparse active days produced **0 findings, 10 skipped** — the correct answer. Design notes: `docs/RULES_ENGINE.md`.

12.4 Sync/async, caching, regeneration

- **Synchronous** — the request awaits four aggregations then returns.
- **Not cached** — recomputed on every page load and every window change.
- **Not scheduled** — there's no background job producing insights.
- **Failure:** caught → `500 {success:false}`; the page shows an error card + "Try again".
- **Insufficient data:** `flowBlocks.blockCount === 0` → focus/flow/churn/read/switch cards render "—" plus a "needs extension 2.1.0" banner; `estimationCalibration null` → prompt to complete a goal.

12.5 "Is this really machine learning?" — the answer

"No, and I wouldn't claim it is. It's descriptive statistics computed deterministically: median absolute deviation for volume stability, 'surviving minutes' for the most productive two-hour window, medians for flow blocks and estimation calibration, and a confidence gate on every number — plus a small rules layer that states what stands out. There's no model, no training data, no inference. I chose that deliberately — every number on the page is explainable and reproducible, and it works from day one with no cold-start problem. The design doc has an LLM layer on top that would *narrate* these metrics — 'your afternoons are busy but churny, your evenings are where you actually ship' — with a hard rule that any number it states must be traceable to the metrics object, to stop it hallucinating. That's specced (Gemini was the pick) but not built."

12.6 The machine-learning plan [DESIGNED, NOT BUILT]

The full plan, in plain language: `docs/ML_INTEGRATION_PLAN.md`. The short version:

- **What:** replace the hand-written `classify()` rule cascade with **k-means clustering** over session feature vectors, so the session archetypes are learned rather than hand-coded.
- **Features — 8, chosen deliberately:** five ratios (`churnRatio`, `readRatio`, `buildFailRatio`, `commandFailRatio`, `deepShare`) and three rates (`linesPerMin`, `commandsPerMin`, `switchesPerMin`). `featureVector()` also returns four absolutes — `activeMin`, `editVolume`, `debugSessions`, `commits` — which are **excluded**: they measure a session's *size*, so clustering on them splits long sessions from short ones instead of debugging from building.
- **Preprocessing:** filter out sessions too thin to classify (the same guard `classify()` uses), then scale per user, falling back to global scaling for users with too few sessions.
- **Train offline, serve in JavaScript:** scikit-learn in a notebook; only the $k \times 8$ centres are stored, versioned, in MongoDB; the API assigns the nearest centre. No Python in production.
- **Evaluation without labels:** the elbow method and silhouette score choose k , and an agreement table against the existing rules turns the rule cascade into the yardstick. Supervised metrics such as RMSE or AUC do not apply — there is no label.
- **The trap:** thin legacy sessions are all-zero vectors that form one perfectly tight cluster and inflate the silhouette score. Filtering first is not optional.
- **Why it is not built:** on 2026-09-16 there were 4 usable sessions from 1 person and 0 completed goals. A model trained on that would be confident nonsense.

- **Other routes considered:** supervised goal-slip prediction (blocked — no completed goals), anomaly detection on ingest, and the LLM narration layer with a validator that rejects any figure not present in the metrics object.
-

13. Authentication & authorization

13.1 Web auth flow [ACTUAL IMPLEMENTATION]

1. `Login.tsx` → `window.location = API_URL + '/auth/google'`.
2. `GET /auth/google` → `passport.authenticate('google', { scope:['profile','email'], session:false })`.
3. Google redirects to `/auth/google/callback`. Passport's verify callback find-or-creates the `User` (new → `generateApiKey()`), returns the user.
4. Handler signs `jwt.sign({id,name,email,isFirstLogin}, JWT_SECRET, {expiresIn:'1d'})`, sets cookie token (`httpOnly; prod: secure + sameSite:'none'; dev: lax; maxAge 24 h`), redirects to `FRONTEND_URL + '/onboarding' | '/dashboard'`.
5. `Frontend App.tsx` → `GET /api/user/profile (credentials:'include')` — 200 renders the app, anything else → `/login`.
6. `isAuthenticated` on protected routes: `jwt.verify(req.cookies.token) → User.findById(decoded.id) → req.user`.
7. `POST /auth/logout` clears the cookie.

13.2 Extension auth

API key in `x-api-key`; `verifyApiKey` → `User.findOne({ apiKey })`. See §5.

13.3 Authorization [ACTUAL IMPLEMENTATION]

- `services/authorization.js`:
 - `sameUser(a,b)` — `String(a) === String(b)`, null-safe.
 - `assertOwnership(requestedId, sessionId)` → {ok} if IDs match or requestedId is falsy; 403 if they differ; 401 if no session.
 - `isBypassAllowed(env)` — `AUTH_BYPASS === 'true' && NODE_ENV !== 'production'`.
- **Analytics routes:** `resolveOwnedUserId(req,res)` calls `assertOwnership` → 403 on mismatch (H-1 fix).
- **Metrics:** no `:userId` at all — identity is the session (`req.user._id`).
- **Goals:** `Goal.findOne({ _id: goalId, userId: req.user.id })` — scoped (H-11 fix).
- **Teams:** `GET /:teamId` checks `team.members.some(sameUser(..., req.user.id))` → 403; `add-member` checks `team.createdBy === req.user.id` → 403.
- **Groups:** `:groupId/details` checks `GroupMember.findOne` → 403.
- **Notifications:** every query scoped by `req.user._id`.

13.4 Gaps

- No refresh token — 24 h then a hard logout.
- No server-side revocation / session list — a stolen JWT is valid until expiry.
- `JWT_SECRET` was a hardcoded fallback — now required at boot (M-9, fixed 2026-09-09).
- `sameSite:'none'` in production + no CSRF token — limited exposure because most mutations are `POST` with a JSON body and `credentials:'include'`, but `POST /auth/logout` and the no-body `POST`s

are technically CSRF-able (low impact).

- Group `createdBy` is stored but never used for authz.
-

14. Security analysis

Format: **Current** → **Vulnerability** → **Attack** → **Fix**.

14.1 API key — plaintext bearer credential

- **Current:** 256-bit random, stored plaintext, compared with `findOne({apiKey})`, no expiry, no scope, sent every request, shown in the dashboard and pasted into `settings.json`.
- **Vulnerability:** DB read → all keys usable; key in logs/history/dotfiles → account ingest hijack.
- **Attack:** `for i in {1..1000}; do curl -XPOST ../api/extension/track -H "x-api-key: $K" -d '{"fileName":"a.ts","language":"TS","duration":3600}'; done` → victim tops the leaderboard; their analytics are garbage.
- **Fix:** hash at rest (`keyId+secret`, prefix), per-device keys, rotation with grace, scope, `lastUsedAt`; or short-lived signed ingest tokens; rate-limit + validate + idempotency on ingest.

14.2 Rate limiting — partial (as of 2026-09-09)

- **Now:** `express-rate-limit` on `/auth` (50 / 15 min) and `/api/extension` (120 / min), skipped under `NODE_ENV=test`. `trust proxy` is set so the client IP is correct behind Render.
- **Added 2026-09-12 (M-24):** `/api/groups/:groupId/join` at 10 per IP per 15 min — a private group is gated by one shared password, so it was an unlimited guessing surface — and `/api/analytics` at 120/min, because each call is unbounded aggregation work.
- **Still uncapped:** there is no *per-key* quota on ingest (only per-IP).
- **Next:** per-key limits + an idempotency key on ingest (#10, deferred).

14.3 Security headers — done (2026-09-09)

- **Now:** `app.use(helmet())` — HSTS, `X-Content-Type-Options: nosniff`, `X-Frame-Options`, NO `X-Powered-By`. CSP is left off (helmet's default) since the SPA is served from Vercel.
- (The old `server.js.old` had `helmet`; it was dropped in the rewrite and re-added here.)

14.4 Ingest input validation — fixed 2026-09-09 (M-4, partial)

- **Was:** only if `(!fileName || !language || !duration)` — `Number(duration)` accepted `1e12` and negatives, and `timestamp` was unbounded. One request with `duration: 999999999` → instant leaderboard #1.
- **Now:** a pure `services/ingestValidation.js` (`validateIngestPayload`, 23 unit assertions) runs on `/track` and each `/track/batch` element: `duration ∈ (0, 3600]`, `fileName ≤ 255`, `language ≤ 64`, `projectName ≤ 128`, `timestamp ∈ [now-24h, now+60s]` → `400 { details }`.
- **Still open:** `timestamp` is client-supplied (bounded, not server-set); no per-key quota (only the per-IP `/api/extension` limiter); no idempotency key (#10, deferred).
- **Chosen** a pure module over `express-validator` — more testable, slots ahead of the normalise/plan pipeline. Original sketch was: `express-validator` — `duration` `int 1..3600`, `timestamp` within `[now-24h, now]`, `language/fileName` length caps, reject unknown top-level keys.

14.5 Error messages leaked internals — fixed 2026-09-09

- **Was:** `res.status(500).json({ message, error: error.message })` in every route — provoking errors leaked stack shapes, field names, Mongo error text.
- **Now:** a central `(err, req, res, next)` handler (registered after the routers) logs the full error server-side with a short correlation id and returns `{ error: 'Internal server error', id }`. Routes call `next(err)`; deliberate 4xx bodies (with fixed strings) stay per-route. `try/catch` wrappers kept for now.

14.6 Leaderboard exposed every user's email — FIXED 2026-09-12 (M-23)

- **Was:** `GET /api/leaderboard` returned `email` on every row, to every signed-in user — 35 accounts on the live install.
- **Now:** the field is gone from the projection and the response, and the frontend no longer renders the handle derived from it. `quickWins.test.js` asserts both.

14.7 AUTH_BYPASS — fixed, but note it

- **Current:** `isBypassAllowed` returns false when `NODE_ENV==='production'`, and the middleware refuses it; tests assert this (H-10).
- **Residual:** still a big footgun in dev; anyone running the API with `NODE_ENV` unset and `AUTH_BYPASS=true` is fully open.

14.8 JWT

- **Current:** `HS256`, `JWT_SECRET` (required at boot), 1-day, `httpOnly` cookie, no refresh, no revocation.
- **Attack:** if the fallback secret is ever live, anyone can forge a token for any `id`.
- **Fix:** fail fast if `JWT_SECRET` is unset (M-9); add refresh + a rotating secret or `RS256`.

14.9 No idempotency / replay protection on ingest

- **Attack:** capture one valid POST, replay it N times → N× the activity.
- **Fix:** client `idempotencyKey` (uuid per flush) + a unique index / short-lived dedupe set.

14.10 MongoDB injection

- **Was:** `Group.find({ name: { $regex: search, $options: 'i' } })` — `search` was user input used as a regex → **ReDoS** (a pathological pattern pins the event loop) and `.*` listed every group.
- **Fixed 2026-09-10 (H-16):** `services/textQuery.js` escapes every metacharacter, trims, and caps the term at 128 chars; `/discover` also caps results at 100. A test asserts `(a+)+$` against a 4,000-character string returns in under 500 ms once escaped.
- Elsewhere queries pass values as query *values* (not `$where`, not string-concatenated), so classic NoSQL operator injection is limited — but `express.json()` will happily parse `{"apiKey": {"$ne": null}}` as a body; `verifyApiKey` does `typeof apiKeyHeader === 'string'` on the **header**, so that path is safe. Worth auditing any place a raw body object reaches a query.

14.11 XSS / CSRF

- **XSS:** React escapes by default; no `dangerouslySetInnerHTML` in the codebase → low risk. User-controlled strings (group names, goal titles) render as text.
- **CSRF:** `sameSite: 'none'` + no token → the no-body POSTs are theoretically forgeable; impact is low (logout, onboarding flag, key regeneration — the last is a mild annoyance vector). Add a CSRF token

or `sameSite: 'lax'` + a separate ingest origin.

14.12 Extension security

- Key in `settings.json` not `SecretStorage`.
- Command strings sanitised before transmit (`token=***`), truncated to 120 chars — good.
- Never transmits file contents, diffs, commit messages, or absolute paths — verified by `activation.test.js` (payload must not contain the workspace path).

15. Error handling & reliability

Failure	What happens now [ACTUAL]	Weakness	Fix [RECOMMENDED]
MongoDB down at boot	<code>mongoose.connect().catch(console.error)</code> — process keeps running	every request then throws a generic 500	health check that fails readiness; retry with backoff; <code>/health</code> reports DB state (the old server did)
MongoDB down mid-request	route <code>try/catch</code> → <code>next(err)</code> → central handler → <code>500 { error, id }</code>	generic body (fixed 2026-09-09); still no transient-error retry	add a retry wrapper for transient Mongo errors
Ingest: malformed payload	normalisers coerce sub-docs to 0; missing <code>fileName/language/duration</code> → 400	<code>duration:0</code> rejected; <code>1e12</code> accepted; junk timestamp → <code>now</code>	<code>express-validator</code> with bounds
Ingest: invalid key	<code>401 { message: 'Invalid API key' }</code>	fine	+ rate-limit to slow enumeration
Extension offline	the unsent payload is merged forward into the next flush (<code>mergeAnalytics</code> , 2.4.0); best-effort flush on deactivate	restart still loses un-flushed time. Before 2.4.0 the retry was dead code — <code>sendActivity</code> never rethrew, so every failed upload was lost	persist the buffer to <code>context.globalState</code> ; a small on-disk queue
Frontend API failure	<code>console.error</code> , page stays in empty/loading or shows an error card	inconsistent; <code>Groups</code> uses <code>alert()</code>	a shared fetch hook with typed errors + toasts; React Query retry
Metrics/ML failure	<code>500 {success:false}</code> → "Could not load your insights" + retry	fine	+ a cached last-good result
Notification cron on serverless  fixed 2026-09-09	was: never fires / cold-start re-run (H-13)	—	<code>require.main</code> guard + <code>POST /api/internal/run-*</code> behind <code>INTERNAL_CRON_SECRET</code>
Unhandled rejection	Express 5 turns it into a 500	no logging context	central handler + <code>process.on('unhandledRejection')</code>

16. Performance & scalability (10k → 1M users)

Assume ~2 active hours/user/day. Since 2026-09-08 that's ~ **12 bucket writes/user/day** (≈ 1 write per 10 active minutes), not ~120 — the bucket `$inc` upsert absorbed the volume.

10,000 users [ACTUAL: mostly fine]

- **Writes:** ~tens of upserts/min peak — trivial for one Mongo node (each is one indexed `findOneAndUpdate`, slightly dearer than an insert but $\sim 10\times$ fewer of them).
- **Storage:** `activities` grows $\sim 10\times$ slower now; the 400-day TTL caps it; `dailysummaries` is tiny.
- **Leaderboard:** still the **first thing to break (H-7)** — the all-collection `$group` + `$addToSet` + load-all-users. Bucketing shrinks the doc count $\sim 10\times$ (buys time) but the complexity class is unchanged; needs the `UserStats` rollup.
- **Analytics:** `find(7d)` per user is now bounded to ~hundreds of docs and uses the new `{userId:1,timestamp:-1}` index; still ships them to Node to aggregate (M-1).
- **Frontend:** every nav refetches — noticeable but survivable.

100,000 users

- **Leaderboard is dead** without a rollup.
- **Ingest** ~ thousands of writes/min — one Mongo primary is still okay but the connection pool on a small Render instance is a bottleneck; the synchronous `Activity.create` per request ties up an event-loop turn on JSON parse + write ack.
- **No caching** → repeated identical analytics/metrics recomputation.
- `node-cron` sweeping all overdue goals with an unindexed `findOne` per goal is now expensive.

1,000,000 users

- **Single monolith + single Mongo is the wrong shape.** Need:

```
Extensions → API (stateless, autoscaled) → Queue (SQS/Kafka) → Ingest workers → activities
(sharded by userId)                                     ↳ $inc UserStats /

daily_stats rollups
Dashboard → API → read from rollups + Redis cache
Leaderboard → Redis sorted set (ZADD on rollup update)
Insights → batch worker writes `insights` collection nightly; API serves cached
```

- **Shard activities on userId** (hashed) — all per-user queries are single-shard.
- **Rollups** (`UserStats`, `daily_stats`) so reads are $O(\text{users})$ not $O(\text{activity})$.
- **Redis:** leaderboard sorted set; per-(user>window) insights cache; rate-limit counters.
- **Queue** decouples ingest spikes from write latency and lets you replay/repair.
- **CDN + React Query** on the frontend; HTTP caching headers on analytics.
- **Archival:** raw `activities` older than N months → cold storage / a columnar warehouse (BigQuery/ClickHouse) for trend analysis.
- **Observability:** structured logs, RED metrics, tracing — currently zero.

What to say

"The architecture is fine to about 10k users. The first thing that breaks is the leaderboard, because it aggregates the entire activity collection in application memory on every request. The fix is a `UserStats` rollup updated on ingest, which turns an $O(\text{all activity})$ scan into an $O(\text{users})$ indexed read, and a Redis sorted set if I want $O(\log n)$ rank lookups. Past ~100k I'd put a queue in front of ingest so write spikes don't raise latency, shard activities by `userId`, and move analytics aggregation from Node into MongoDB pipelines or precomputed rollups. The read path would sit behind Redis and React Query."

17. Testing

17.1 What exists [ACTUAL IMPLEMENTATION]

Framework: none. Plain `node:assert` scripts with a hand-rolled `check(name, fn)` counter, run via `node tests/x.test.js`. `package.json` test scripts chain them with `&&`. **CI:** GitHub Actions (`.github/workflows/ci.yml`, added 2026-09-09) runs the backend + extension suites and the frontend build on every push / PR.

Backend (`backend/tests/`, 18 suites, 292 assertions):

Suite	Technique	Covers
<code>streak.test.js</code>	extracts <code>localDayInfo</code> + <code>computeStreak</code> from the <i>shipped</i> <code>analytics.js</code> via string slicing, runs them against a stubbed <code>Activity.aggregate</code>	streak correctness incl. one regression case per historical bug; timezone day-bucketing
<code>ingest.test.js</code>	unit	<code>activityNormalizers</code> — defaults, number coercion, negative rejection, <code>flowBlocksMs</code> cap at 200
<code>metrics.test.js</code>	unit	every <code>metricsDerive</code> function, rewritten 2026-09-10 (37): block-time deep-work denominator, MAD stability, cadence, 2-hour peak with a day floor, median calibration, confidence thresholds
<code>authorization.test.js</code>	unit	<code>sameUser</code> , <code>assertOwnership</code> (403 vs 404 vs 401), <code>isBypassAllowed</code> (never in prod)
<code>routeGuards.test.js</code>	static source scan — regex over route files	fails if any sensitive route loses <code>isAuthenticated</code> / ownership; the H-1 regression guard
<code>passwordHash.test.js</code>	unit (async)	scrypt round-trip, wrong password, salting, legacy plaintext acceptance, null-safety

Suite	Technique	Covers
activityBucket.test.js	unit (pure)	bucket math (bucketStartFor), hasSignal, buildBucketUpdate shape, planActivityWrite legacy/merge/bucket modes (2026-09-08)
activityModel.test.js	schema introspection	Activity sub-doc leaves are sparse (no default: 0); date path gone; bucketStart/files/flushCount present; the 5 index specs incl. the partial-unique bucket key (2026-09-08)
ingestWiring.test.js	static source scan	/track uses planActivityWrite; ACTIVITY_BUCKET_MS default 600000; bucket writes are findOneAndUpdate ... upsert; 11000 retry; the read paths tolerate bucketed docs (2026-09-08)
rollup.test.js	unit (pure)	buildDaySummary — seconds/lines summed, flushCount missing ⇒ 1, per-language breakdown, project de-dup, focus longestBlockMs maxed (2026-09-08)
quickWins.test.js	static source scan	JWT_SECRET boot-guard + no 'your_jwt_secret'; 11000 → 409 on group join; GET /health on readyState; helmet + rate-limit on /auth + /api/extension (test-skip); central (err, req, res, next) handler + zero response-body .message leaks; require.main bootstrap guard; /api/internal + INTERNAL_CRON_SECRET; {goalId:1,type:1} index (2026-09-09)
ingestValidation.test.js	unit (pure)	validateIngestPayload — duration ∈ (0,3600], fileName/language/projectName length caps, timestamp ∈ [now-24h, now+60s]; numeric-string coercion; null body (2026-09-09)
metricsService.test.js	unit vs stubbed Activity, Goal, UserInsights	buildMetrics on fixtures: meta/confidence, goal pairs, baseline attach, sessions (2026-09-10)
sessionize.test.js	unit (pure)	collapse by bucket, then 30-min gap split; legacy timestamp fallback; archetype rules and mix (2026-09-10)
insightsBaseline.test.js	unit (pure + stubs)	staleness, 90-day window, ungated metrics skipped, failure fallbacks, deltaFrom (2026-09-10)

Suite	Technique	Covers
<code>textQuery.test.js</code>	unit (pure)	metacharacter escaping, ReDoS pattern returns fast, length cap, anchored exact match (2026-09-10)
<code>leaderboardScore.test.js</code>	unit (pure)	<code>score()</code> clamps [0, 5] and rejects non-finite input; <code>maxOf</code> survives 200k rows where <code>Math.max(...spread)</code> throws (2026-09-10)
<code>rulesEngine.test.js</code>	unit (pure)	rule validation at load, confidence gating (a missing meta entry never passes), each rule's thresholds, ordering, cap, error containment (2026-09-10)

Extension (`extension/tests/`, 3 suites, 52 assertions):

Suite	Technique	Covers
<code>trackers.test.js</code>	unit against the built <code>dist/extension.js</code> + a <code>vscodeStub</code>	EditorTracker (gross counts, replace-in-place regression, churn window, undo/redo, attention split, large-insert-no-text), FocusTracker (focus/blur accrual, block close/gap/open), GitStateTracker (commit on HEAD move, no double-count, uncommitted age, no-op without git)
<code>activation.test.js</code>	loads the real bundle vs stub, activates it	every contributed command registered; no undeclared commands; no network call without a key ; payload has the 4 analytics blocks + gross line fields; no absolute path leak; manifest sanity (<code>apiBase</code> not <code>localhost</code> , <code>prepublish</code> compiles)
<code>flushSafety.test.js</code>	unit (pure)	<code>mergeAnalytics</code> carry-forward (sums, 200-cap arrays, maxima, rate recomputation) and the idle pause gate — <code>focusedMs</code> flat across a 5-hour idle, no back-fill (2026-09-10)

Frontend: zero tests.

17.2 Gaps

- No integration tests (nothing boots Express + hits a real/in-memory Mongo).
- No API contract tests (supertest).
- No end-to-end (`extension` → `API` → `DB` → `dashboard`).
- No frontend component/hook tests.
- Tests never touch a database — backend verification is unit-level and source-scan. The only live-DB runs were read-only probes (`measure-insights.js`, `probe-activity-shape.js`).

17.3 Recommended strategy [RECOMMENDED IMPROVEMENT]

- **Unit (keep the style, add a runner):** move to `node:test` or `Vitest`; cover `buildTerminalSummary`, `localDayInfo`, `resolveOwnedUserId`, `computeStreak` against `mongodb-memory-server`.
 - **Integration (backend):** `supertest` + `mongodb-memory-server`. Cases:
 - ingest with a valid key writes exactly one doc with normalised sub-docs;
 - ingest with a bad key → 401; missing fields → 400;
 - `GET /api/analytics/:otherUserId` with my cookie → 403;
 - `GET /api/metrics` returns zeros for a fresh user and non-zero after seeded activity;
 - leaderboard ordering with 3 seeded users;
 - group: create → creator is a member → second user joins with the right/wrong password → third user `/details` → 403 (not a member);
 - notification: mark-as-read only affects my rows.
 - **Frontend:** React Testing Library — App renders `Login` when profile 401s; `Insights` shows the "2.1.0" banner when `blockCount === 0`; Dashboard toggles daily/weekly; `NotificationPanel` badge count.
 - **Extension:** extend the stub to fire full event sequences; assert flush cadence, idle pause/resume, retry-keeps-buffer, deactivate final flush.
 - **ML/metrics:** property tests — `consistencyIndex ∈ [0,1]`, `deepWorkRatio ≤ 1`, `truePeakWindow.hour ∈ 0..23`; golden-file test of `buildMetrics` against a fixed seeded DB.
 - **E2E:** Playwright against a compose stack (Mongo + API + built frontend), plus a headless extension host test (`@vscode/test-electron`, already a devDep).
 - **CI:**  `.github/workflows/ci.yml` added 2026-09-09 — 3 jobs: backend `npm test`, extension `npm test` (its `pretest` builds the bundle), frontend `npm run build` (`tsc -b` + `vite build`). Still to add: `node --check`, a `vsce` package dry run, and lint.
-

18. Debugging playbook

18.1 "A user's VS Code activity isn't on the dashboard."

Walk it in order (this is `CodeTrackr_Architecture.md` §9 as a checklist):

1. **Extension running?** `CodeTrackr`: Show Connection Info → backend URL, masked key, live status. Show `Statistics` → pending minutes, counters. If "Paused (idle)" — expected.
2. **API key valid?** `showInfo` calls `GET /api/extension/verify`. 401 → regenerate on Profile, re-run Setup API Key. Check for a trailing space (the code `.trim()` s the header but not always the stored value historically).
3. **Right backend?** `codetrackr.apiBase` — the 2.0.x regression pointed it at `localhost`. Should be `https://codetrackr-backend-uckp.onrender.com` (or your deploy).
4. **Is it flushing?** Dev tools / `console` in the Extension Host: look for "Activity tracked  " or "flush failed". Under `minFlushMinutes` (default **2** in 2.3.0), or a flush with no real signal → nothing sent yet. Run `CodeTrackr: Flush Now`.
5. **Network:** backend reachable? Render free tier asleep (first request ~30 s)? `axios` 15 s timeout — a cold start can exceed it once.
6. **Backend logs:** "Track activity error" → 400 (missing field) or 500 (Mongo). Confirm the doc landed: query `activities` by `userId` (the **string** hex) + recent timestamp.
7. **Dashboard fetch:** DevTools Network → `GET /api/analytics/<id>` — 401 (session expired → re-login), 403 (wrong `<id>` — should be `user.id` from the profile), missing `credentials: 'include'` (was the H-1 bug).

8. **Timezone / "wrong day":** a flush near local midnight can bucket to the previous/next day; the daily view is *today in the browser's local day*. Check `?timezone=` is sent (it's `new Date().getTimezoneOffset()`).
9. **Insights focus cards** show "—" until 2.1.0 data exists; weekly vs daily toggle. (*The "Repeated Failures" panel was mock data — wired to real data 2026-09-09.*)

18.2 More scenarios (give a step-by-step for each in an interview)

- **"Leaderboard is slow / times out."** → it aggregates the entire `activities` collection per request (H-7); confirm collection size (`db.activities.countDocuments()`); short-term add a 30-day `$match` + `$limit` in the pipeline; medium-term a `UserStats` rollout.
- **"Two users have the same rank."** → ties break on array order; `rank = index + 1` with no tie handling; decide the tie-break rule (e.g. more recent activity, then `userId`).
- **"My streak reset even though I coded yesterday."** → `computeStreak` anchors on *today or yesterday*; check the 90-day window, the timezone offset, and whether yesterday's flush had `duration > 0` (the `$match: { seconds: { $gt: 0 } }`).
- **"Insights says 0% deep work."** → `flowBlocks.blockCount` — if 0, they're on a pre-2.1.0 extension; the UI should show "—" not "0%" (it does, gated on `hasFocusData`).
- **"Goal progress looks wrong."** → progress only counts activity where `language === goal.techStack` **exactly** (case-sensitive string match) and `timestamp <= deadline`; a goal with `techStack: 'React'` won't match `language: 'javascript'`.
- **"Notifications never arrive."** → is the backend serverless? `node-cron` won't fire (H-13). On Render, check the process stayed up (free tier sleeps).
- **"npm run build on the frontend."** → ✅ green 2026-09-09 (was `tsc -b` 29 errors, M-13); `vite build` alone would succeed.
- **"Duplicate activity after a flaky network."** → no idempotency; the retry re-sent and the backend stored both.

19. Deployment / DevOps

19.1 What's in the repo [ACTUAL IMPLEMENTATION]

- **Frontend:** `frontend/vercel.json` — SPA rewrite `/(.*) → /index.html`. Build: `tsc -b && vite build` (**currently red**). Env: `VITE_API_URL`.
- **Backend:** `backend/vercel.json` — `@vercel/node` build of `api/index.js` (which wraps `app.js` with `serverless-http`), route-all to it. Also runnable as a plain process (`node app.js, app.listen(PORT || 5050)`). The extension's default `apiBase` points at **Render** (`codetrackr-backend-uckp.onrender.com`), which is the live backend (verified 2026-09-12: `GET /health → 200`, auto-deploys `main`); the Vercel config is an unused alternative.
- **DB:** MongoDB Atlas (`MONGO_URI`, TLS, `family:4`, 15 s selection timeout).
- **Extension:** `vsce` package → `.vsix`; publisher `CodeTrackr-ext`; `.vsix` files are gitignored (none committed); **2.4.0** is the published Marketplace version. `PUBLISHING_v2.0.0.md` documents the Azure DevOps PAT + `vsce publish` flow.
- **No Dockerfile, Procfile, or `render.yaml`.** **GitHub Actions CI added 2026-09-09** (`.github/workflows/ci.yml`) — backend + extension tests + frontend build on push / PR; no CD (deploys stay manual).

19.2 Env vars

backend/.env.example: MONGO_URI, JWT_SECRET (required at boot — fixed 2026-09-09), GOOGLE_CLIENT_ID, GOOGLE_CLIENT_SECRET, GOOGLE_CALLBACK_URL, FRONTEND_URL, PORT, NODE_ENV, AUTH_BYPASS (dev only). config/passport.js **throws at import** if the three GOOGLE_* are missing — the API won't boot without them.

19.3 The serverless / scheduler mismatch (H-13) — fixed 2026-09-09

Was: app.js called `initScheduler()` + `app.listen()` unconditionally, so on Vercel serverless every cold start re-ran the immediate sweep and the hourly `cron.schedule('0 * * * *')` never fired (process frozen between requests). **Now:** both are inside `if (require.main === module)` — `require('../app')` (the serverless entry) starts no server and no scheduler. `routes/internal.js` exposes `POST /api/internal/run-notifications` and `/run-rollup` behind `INTERNAL_CRON_SECRET` (constant-time compare, **404** when unset/wrong). Added the `{ goalId:1, type:1 }` index for `checkOverdueGoals`'s per-goal `findOne`. CI imports app.js with junk env and asserts no side effects. **Operator:** set `INTERNAL_CRON_SECRET` and point an external scheduler (GitHub Actions `schedule: / cron-job.org`) at the two routes.

19.4 How I'd deploy it properly [RECOMMENDED IMPROVEMENT]

- Backend: a single Docker image on Render/Fly/Railway (long-lived process → `node-cron` works), or Vercel serverless + Vercel Cron for the schedule. Health check on `/`.
- Frontend: Vercel/Netlify, `VITE_API_URL` per environment, preview deploys per PR.
- DB: Atlas M10+ with backups; a separate cluster per environment.
- Secrets: platform secret stores, never `.env` in git (it's `.gitignored` here — verified).
- CI: GitHub Actions — `lint` + `tsc -b` + both test suites on PR; on tag, build the `.vsix` and `vsce publish` with a PAT in Actions secrets; deploy hooks for Render + Vercel.
- Observability: a hosted logger (structured JSON), uptime checks, error tracking (Sentry).

20. Design decisions — "why did I choose this?"

Each: **Decision** → **Reason** → **Alternative** → **Trade-off** → **When the alternative wins.**

D1. MongoDB (not Postgres)

- **Reason:** append-only, self-contained, schema-evolving activity docs; per-user-window access; no hot-path joins; free managed hosting; team familiarity.
- **Alternative:** Postgres (+ Timescale for the stream).
- **Trade-off:** no transactions; `userId` type mismatch; the leaderboard scan; weaker relational integrity for groups/teams/goals.
- **Postgres wins when:** the relational features grow (roles, invites, cascades), the leaderboard needs `GROUP BY` at scale, or you want real analytics SQL.

D2. Modular monolith (not microservices)

- **Reason:** one dev, one deploy, one DB, shared model; features aren't independently scalable yet.
- **Alternative:** ingest service + analytics service + web BFF.
- **Trade-off:** the whole thing scales together; a slow leaderboard query can starve ingest.
- **Microservices win when:** ingest volume dwarfs everything (extract it + a queue), or teams need independent deploys.

D3. API key for the extension (not OAuth / JWT)

- **Reason:** no login UI in VS Code; one `findOne`; works offline once configured; trivial to regenerate.
- **Alternative:** OAuth device flow; short-lived signed ingest tokens; a JWT the dashboard mints.
- **Trade-off:** unscoped, non-expiring, plaintext bearer credential; leak = ingest hijack; all-or-nothing rotation.
- **The alternative wins:** basically always for production — but the key model is a legitimate MVP. (Full redesign in §5.4.)

D4. Google OAuth → JWT in an httpOnly cookie (web)

- **Reason:** no password storage; stateless; survives serverless cold starts; `httpOnly` blocks JS theft.
- **Alternative:** server-side sessions; a managed auth provider.
- **Trade-off:** no revocation; no refresh; `JWT_SECRET` fallback; CSRF surface with `sameSite: 'none'`.
- **Sessions win when:** you need instant logout-everywhere or per-session device management.

D5. 10-minute bucket-on-write (*changed 2026-09-08 — was "one document per flush"*)

- **Original reason for per-flush:** simplest write; immutable; no read-modify-write races.
- **Why it changed:** document count grew ~1 per 30–90s of coding, and every doc repeated the metadata + four mostly-zero analytics objects. The ingest route now does an atomic `findOneAndUpdate` with `$inc` into a (`userId`, `projectName`, `language`, 10-min window) document — race-safe because `$inc` in one update is atomic (unlike `server.js` old's read-then-`.save()`). 10 minutes is the finest window any read uses, so no dashboard lost resolution. `$inc.duration` is the real measured seconds — **totals are identical**.
- **Trade-off accepted:** time-of-day precision is now the 10-minute grid; a `repeatedFailedCommands` list is last-writer-wins per bucket.
- **Kept:** `ACTIVITY_BUCKET_MS=0` still does the plain per-flush `Activity.create`.
- **Still ahead:** a `DailySummary` rollup exists (nightly job); repointing the all-time reads at it + tightening the raw 400-day TTL is the follow-up.

D6. Aggregate analytics in Node (not MongoDB `$group`)

- **Reason:** honestly, expedience — `find().then(reduce)` was faster to write and easier to debug while the metric definitions were changing.
- **Alternative:** `$match/$group/$facet` pipelines (the metrics service already does this).
- **Trade-off:** ships and parses every document; memory $O(N)$; the M-1 tech-debt item.
- **`$group` wins:** always, once the definitions stabilise — it's the prerequisite for scale.

D7. Deterministic statistics for Insights (not ML / not an LLM)

- **Reason:** explainable, reproducible, no training data, no cold start, cheap; every number defensible in a review.
- **Alternative:** clustering for session archetypes; an LLM narration layer (designed).
- **Trade-off:** no personalised recommendations, no natural-language summary, no learning.
- **ML wins when:** you have labelled outcomes (goal slippage, retention) and enough users; the LLM layer wins for UX once there's a validator to stop hallucinated numbers.

D8. `groupmembers` join table but `teams.members` embedded array

- **Reason:** groups are the real feature (discover, join, leaderboard) and need efficient membership queries + a uniqueness guard; teams were an earlier, smaller idea.
- **Trade-off:** two patterns for "membership"; `team.members.push` has a lost-update risk; inconsistent mental model.
- **Consolidate:** move teams to a join table too, or drop teams (the UI already doesn't use it).

D9. React + Vite (not Next.js)

- **Reason:** auth-gated app, no SEO need, no SSR need; Vite is the simplest fast build.
- **Alternative:** Next.js (routing, API routes, SSR), Remix.
- **Trade-off:** you assemble routing/data-fetching yourself (and here, didn't finish — no React Query despite it being installed).
- **Next wins when:** you want SSR/ISR, co-located API routes, or file-based routing.

D10. 28 runtime themes via a Context + inline styles

- **Reason:** a fun differentiator; DaisyUI-style palettes without DaisyUI.
- **Trade-off:** every component carries `style={{ color: theme.colors.x }}`; verbose; `tailwind.config` `extend` is empty so utilities can't use the theme.
- **Better:** CSS custom properties + Tailwind `theme.extend` referencing them → `text-primary` just works.

21. Known limitations

21.1 Current limitations (this is a class/side project)

#	Problem	Why it matters	Impact	Fix
1	API key plaintext, non-expiring, unscoped  built 2026-10-03	it's a credential, not an id	—	SHA-256 at rest (<code>ct_{id}_{secret}</code>), shown once; per-device keys via device-code sign-in, 1-year expiry, revocable; SecretStorage in the extension
2	Leaderboard scans all activity  built 2026-10-03	was $O(A+U)$ per request	—	<code>userstats</code> running totals: 1M rows p50 6.72 s → 62 ms (local benchmark); windowed boards still scan their window
3	Analytics aggregate in JS  built 2026-10-03 (daily/weekly)	—	—	one <code>\$facet</code> pipeline, proven equal to the old code by an oracle test

#	Problem	Why it matters	Impact	Fix
4	Missing <code>{userId:1,timestamp:-1}</code> index  fixed 2026-09-08	—	—	index added, <code>date</code> dropped
5	node-cron on serverless  fixed 2026-09-09	was: frozen between requests (H-13)	—	<code>require.main</code> guard + external <code>/api/internal/run-*</code> trigger
6	No helmet / rate limit / validation  fixed	—	—	helmet; rate limits incl. group <code>/join</code> (2026-09-12) and a per-key ingest quota (2026-10-03). Still per IP (H-20)
7	Frontend doesn't typecheck  fixed 2026-09-09	was 29 <code>tsc -b</code> errors	—	<code>npm run build</code> is green; CI enforces it
8	Dashboard "Repeated Failures" is mock  fixed 2026-09-09	was fabricated commands	—	now renders <code>terminalSummary.repeatedFailedCommands</code>
9	Goals: no edit/delete	half-built to-dos were removed; complete/reopen exist (and work in browsers since H-23)	minor	add edit/delete routes
10	Teams UI orphaned  deleted 2026-10-03	—	—	page, route and model removed
11	Idle < 2 min counts as active	totals skew high	inflated hours	count only intervals with a real edit event (L-7)
12	<code>activities.userId</code> String vs ObjectId (M-6) —  migrating	—	—	expand step built 2026-10-03: ObjectId writes, dual reads, migration script; live <code>-apply</code> + contract pending
13	No offline queue  built 2026-10-03 (extension 2.5.0, live since 2026-10-04)	—	—	persisted FIFO outbox in <code>globalState</code>
14	No idempotency  built 2026-10-03	—	—	<code>flushId</code> + unique receipts, 48 h TTL
15	Insights recomputed every request	4 aggregations per page load	slow page, DB load	cache per (user, window)

#	Problem	Why it matters	Impact	Fix
16	Errors echo err.message ✓ fixed 2026-09-09	was a recon aid	—	central error middleware + correlation id
17	Leaderboard exposes emails ✓ fixed 2026-09-12	PII in a shared list	privacy	name only, asserted by a test
18	No frontend/e2e tests	UI regressions slip	—	integration tests exist since 2026-10-03 (35, supertest + in-memory MongoDB); next: React Testing Library, Playwright
19	Cross-site auth cookie (H-19)	Safari/Firefox/incognito logins likely fail	blocks a campus launch	proxy the API through Vercel, or a custom domain
20	Leaderboard can still be paced by a script	timestamps are client-chosen	one credited hour per real hour	server-side anomaly checks once there is data

21.2 Production-level concerns (would block a real launch)

- Observability is basic: JSON logs with request ids and optional Sentry (2026-10-03); no metrics or tracing.
- CI runs unit + integration tests, the build and a Docker health check; a deploy-on-green workflow exists but is off until a secret is set; `vsce publish` is still manual (`docs/RELEASE.md`).
- No backups/DR story documented.
- Anti-cheat is bounded, not solved: credited time is capped per window (2026-10-03), but timestamps are client-chosen.
- No data-retention / privacy policy for a tool that records developer behaviour; GDPR-style "export/delete my data" not implemented.
- Single points of failure: one Mongo, one API instance, Render free-tier sleep.
- Extension version-management incident (a `2.1.0` uploaded before `2.0.x` meant the Marketplace served stale code for months) — needs a release checklist + CI publish.

22. Future improvements roadmap

Done 2026-09-08 (DB write-reduction batch)

- ✓ 10-minute bucket-on-write (`$inc` upsert); extension 2.3.0 skip-empty + `minFlushMinutes` 2.
- ✓ Sparse analytics sub-docs; dropped the dead `date` field + index.
- ✓ Added `{userId:1,timestamp:-1}`; `DailySummary` + nightly rollup + 400-day TTL.

Done 2026-10-03 (October roadmap — built, tested, deployed 2026-10-03; extension 2.5.0 live 2026-10-04; migrations pending)

- ✓ Hashed API keys, device-code sign-in with per-device keys, `SecretStorage`.
- ✓ `userstats` leaderboard + group boards; contest-week windows; group admin.

- ☒ Idempotency key, anti-cheat crediting, per-key quota; persisted extension outbox.
- ☒ `$facet` dashboard pipeline; `userId` → `ObjectId` expand step; React Query; Teams deleted.
- ☒ Integration tests (35); benchmarks; JSON logs + request ids; Dockerfile + deploy-on-green.
- ☒ `docker compose up` (MongoDB + API + website locally, demo data).
- ☒ Login works in every browser: Vercel forwards `/api` + `/auth` (H-19, live 2026-10-03); rate limits per user/session (H-20). Open: M-33 (failed sign-in shows JSON).
- Remaining from the lists below: Redis, warehouse, LLM layer, anomaly detection, data export/delete, WebSockets — all still future.

Short term (days)

- Fix the 29 TS errors ☒ done 2026-09-09 — `npm run build` is green.
- `app.use(helmet());` `express-rate-limit` on `/auth`, `/api/extension`, `/join`.
- `express-validator` bounds on `/track` (`0 < duration ≤ 3600`, timestamp sanity).
- ~~Central error middleware; stop echoing `err.message`~~ ☒ done 2026-09-09.
- Fail fast if `JWT_SECRET` unset.
- Wire real `repeatedFailedCommands` into the dashboard; **add the error/build-success comparison to the group leaderboard** (the original motive — read-path change only); delete or route `Teams.tsx`.
- Guard `app.listen()` behind `require.main === module`; move the cron (deadline + rollup) to an external trigger.
- Run `scripts/migrate-drop-date.js --apply` + `scripts/rollup-daily.js --apply` on the live DB.

Medium term (weeks)

- **API keys:** hash at rest, `keyId` prefix, per-device keys, rotation grace window, `lastUsedAt`.
- **UserStats rollup** updated on ingest (`$inc`) → leaderboard reads $O(\text{users})$; `?period=` + pagination. **Bundle with it:** repoint `/leaderboard`, `/api/analytics/summary` and `/api/metrics >90d` at the existing `dailysummaries` collection, then tighten the raw `activities` TTL from 400 days.
- **Shared aggregation service** — one module doing `$group` for analytics *and* metrics; delete the JS reduce paths (M-1).
- **React Query** (already installed) for caching + dedup + retry across the frontend.
- **Extension offline queue** persisted to `globalState`; **idempotency key** on ingest.
- **Migrate** `activities.userId` → **ObjectId** with a dual-read compat window; then `$lookup` the leaderboard.
- **CI:** typecheck + both test suites + `.vsix` dry run on PR; auto-publish on tag.
- **Integration tests** with `supertest` + `mongodb-memory-server`.

Long term (months)

- Ingest → **queue** → **workers** → **sharded activities** + rollups; **Redis** for the leaderboard sorted set and the insights cache.
 - **Analytics warehouse** (ClickHouse/BigQuery) fed from the stream for trends/cohorts; TTL/archival on raw docs.
 - **The LLM insights layer** — structured-metrics-only prompt, JSON-schema output, a numbers-must-be-grounded validator, per-(user>window) cache.
 - **Session-archetype clustering** and **anomaly detection** (anti-cheat) on ingest.
 - **Personalised recommendations** ("your 3rd hour is your worst — schedule reviews then").
 - **Observability** everywhere; **SLOs**; **data export/delete** for privacy compliance.
 - **Per-device / team dashboards**, real-time group activity over WebSockets.
-

23. Time & space complexity

Let N = a user's activity docs in the query window; A = all activity docs ever; U = all users; D = days in window; B = flow blocks; G = a user's goals.

Operation	Time	Space	Notes / can it be better?
POST /track ingest	$O(w)$ small writes: receipt, w window counters (w = windows the upload spans, usually 1), bucket upsert, <code>userstats \$inc</code> (since 2026-10-03)	$O(1)$	measured ~450 req/s locally, same as one insert (docs/BENCHMARKS.md)
POST /track/batch	$O(k)$ inserts	$O(k)$	<code>insertMany</code> ; unused
<code>verifyApiKey</code>	$O(\log U)$ index lookup on <code>apiKeyId</code> (then <code>devicetokens</code>) + one SHA-256	$O(1)$	hashed keys cost the same as plaintext lookup (since 2026-10-03)
<code>isAuthenticated</code>	$O(1)$ verify + $O(\log U)$ <code>findById</code>	$O(1)$	could cache the user for the request
Daily analytics	$O(N)$ inside MongoDB (<code>\$facet</code>), $O(24)$ rows back (since 2026-10-03)	$O(1)$ app memory	was $O(N)$ transfer + JS reduce over 7 days to show 1
<code>computeStreak</code>	$O(N_{90})$ <code>\$group</code> + $O(90)$ walk	$O(\text{distinct days})$	good enough; index on <code>timestamp</code> would help the <code>\$match</code>
Weekly / timeslot	weekly: same pipeline, $O(7)$ rows back; timeslot: $O(N)$ in JS over a 2-hour window	$O(1)$ / $O(N)$	timeslot is bounded by its window
<code>/summary</code>	$O(N)$ in Mongo (<code>\$group</code>)	$O(\text{days} + \text{langs})$	already a pipeline — the model to follow
Global leaderboard	$O(k \log U)$ — top- k from the <code>totalSeconds</code> index + two $O(\log U)$ max lookups (since 2026-10-03)	$O(k)$	was $O(A)$ aggregate + $O(U)$ merge; 1M rows: 6.72 s → 62 ms p50 (local). Redis ZSET would add $O(\log U)$ "my rank"
Group leaderboard	all-time: $O(M \log U)$ <code>userstats</code> lookups; contest window: $O(A_{\text{member in window}})$	$O(M)$	windowed boards still scan their window
<code>/api/metrics</code>	$4 \times O(N)$ <code>\$group</code> + $O(B \log B)$ sort in <code>flowBlockStats</code> + $O(D \log D)$ median/MAD + $O(24)$ peak + $O(G)$ pairs + $O(S)$ sessionize + $O(R)$ rules	$O(B + D + S)$	only the 90-day baseline is cached — cache the rest per (user, window)
<code>consistencyIndex</code>	$O(D)$	$O(D)$	
<code>truePeakWindow</code>	$O(24)$	$O(1)$	
<code>estimationCalibration</code>	$O(G)$	$O(G)$	

Operation	Time	Space	Notes / can it be better?
EditorTracker consumeChurn	O(R) over recent inserts (bounded by 10-min window)	O(R)	fine
flowBlockStats median	O(B log B) sort	O(B)	B capped at 200 by the normaliser
Dashboard render	O(N) dataset build per chart	O(N)	cheap; not memoised deliberately
Frontend nav	React Query cache, 30 s fresh (Dashboard, Leaderboard, Insights since 2026-10-03)	O(cached queries)	Groups/Goals/Profile still refetch

Headline (updated 2026-10-03): the two costs that used to matter — (1) **leaderboard = O(all activity)** and (2) **analytics = O(N) app memory + DB egress** — were fixed the way this section predicted: precompute running totals (`userstats`) and aggregate in the engine (`$facet`). What remains linear is windowed boards (`?days=`, contest weeks), which scan their window.

24. Code-level questions (with answers)

middleware/auth.js — verifyApiKey

- *What does it do?* Extracts `x-api-key`, `User.findOne({ apiKey })`, attaches `req.user` or 401s. In `AUTH_BYPASS` (dev, non-prod) it attaches the most-active user instead.
- *Why `findOne` on a plaintext field?* Simplicity + the unique index makes it O(log n). It's the design weakness (§5).
- *Race condition?* No — read-only, idempotent.
- *Optimise?* Hash → `keyId` lookup + constant-time compare; cache `apiKey` → `userId` in Redis.
- *If it fails?* `catch` → 500 { `message: 'Failed to authenticate API key'` }.

routes/leaderboard.js — the aggregate

- *Why group by the String `userId`?* `activities.userId` is a String; the pipeline groups on it directly and the Node merge looks users up by `String(user._id)`. (An older version coerced with `$regexMatch/$toObjectId`; removed 2026-09-10.)
- *Time complexity?* O(A) — every activity doc. *Space?* `$addToSet` on every project name.
- *Race?* No, but the result is different on every call (relative scoring).
- *Edge case:* zero users or all-zero stats → `maxOf()` floors at 1. It's a fold, not `Math.max(...spread)`, which throws `RangeError` past ~100k users (H-18).
- *"commits"?* Real git commits since 2026-09-10 (`gitAnalytics.commits`, per-document fallback to the terminal count); it used to be flush count (H-17).
- *Fix?* Rollup collection; move `sort + limit` into the pipeline; window by `timestamp`.

routes/analytics.js — computeStreak

- *What?* Consecutive days (user-local) with `Σ duration > 0`, anchored to today or yesterday, within a 90-day window.
- *Why "or yesterday"?* So a day that hasn't started yet doesn't read as a broken streak.
- *Complexity?* O(N₉₀) for the `$group`, O(90) for the walk.

- *Edge cases tested:* stale-only activity → 0; 10 consecutive days → 10 (old code capped at 7); gap breaks it; UTC vs IST bucketing.
- *Bug risk?* Relies on the `?timezone=` offset being correct; DST transitions inside the window are not special-cased.

`services/metricsService.js` — `buildMetrics`

- *Why split service vs derive?* `metricsDerive` is pure and DB-free so it unit-tests without Mongo; `metricsService` does only the querying.
- *`$ifNull` everywhere?* Metrics depending on 2.1.0 fields must read missing as 0 for old activity.
- *`blocks: { $push: flowBlocksMs }` then flatten in JS?* `$push` of arrays → array of arrays; flattened with `reduce(concat)`. Could use `$reduce/$concatArrays` in the pipeline.
- *Not cached?* Correct — a known gap.

`extension/src/editorTracker.ts` — `consumeChurn`

- *What?* When lines are deleted, attribute them against still-fresh insertions (≤ 10 min) — newest first — and count the overlap as churn.
- *Why newest first?* "I just wrote this and immediately deleted it" is the churn signal; older insertions are more likely "real" code.
- *Complexity?* $O(R)$ over `recentInserts`, which is pruned to the 10-min window each call.
- *Edge case:* deletes with no matching insert → not churn (just `linesDeleted`).

`extension/src/extension.ts` — `flushIfNeeded`

- *Why stamp `timestamp` at interval start?* Stamping "now" pushed every session forward and skewed hour-of-day analytics (H-12).
- *What if `sendActivity` fails?* It **returns false** (it never throws — that was the bug: the caller's `catch` was unreachable and `bufferedMinutes = 0` always ran, losing the interval). The caller now calls `holdPayload(payload)` so the counters merge into the next flush. A 400 is treated as permanent and dropped, so a malformed payload can't poison every later flush. `startedMs = now` — merged forward into the next flush via `holdPayload/mergeAnalytics` (2.4.0). Memory only. *(Before 2.4.0 nothing was retried: `sendActivity` never rethrew, so the caller's `catch` was dead code and every failed upload lost its interval.)*
- *Race?* Single-threaded JS + one timer; `flushNow` and the tick can't truly overlap, but a slow `await` inside one flush while the timer fires again is possible — the second call sees `startedMs` already reset, so it's mostly benign.

`frontend/src/pages/Dashboard.tsx` — **the three fetches**

- *Why does it fetch 3× on mount?* `useEffect([])` calls `fetchAnalytics` + `fetchWeekly`; `useEffect([viewMode])` also calls `fetchAnalytics` on the initial render → one redundant call (M-11). Fix: drop the mount effect, or guard on a "first render" ref, or use React Query.
- *Why `cache: 'no-cache'` + `Pragma`?* To defeat any intermediary caching of analytics — but it also defeats *useful* caching; React Query with a short `staleTime` is the right tool.

`routes/goals.js` — `/:goalId/progress`

- *Why `findOne({_id, userId})` not `findById`?* `findById` leaked another user's goal (title, target, deadline) — H-11.

- *Progress formula?* $\Sigma \text{ activity.duration (where language === goal.techStack \&\& timestamp \leq \text{deadline})} / 3600 / \text{targetHours} * 100$, capped at 100.
- *Weakness?* Exact case-sensitive `language` match; `techStack` is free text ("React" vs "javascript"); no fuzzy/alias mapping.

25. Codebase map

Path	Purpose	Key functions/classes	Interview relevance
backend/app.js	Express bootstrap	route mounts, mongoose.connect, initScheduler, app.listen	"walk me through a request"; serverless mismatch
backend/api/index.js	Vercel adapter	serverless(app)	deployment
backend/config/passport.js	Google OAuth	GoogleStrategy verify, generateApiKey on new user	auth flow; where the key is born
backend/middleware/auth.js	Auth	isAuthenticated, verifyApiKey, bypassEnabled, resolveTestingUser	core — JWT vs API key, AUTH_BYPASS
backend/models/Activity.js	Activity schema + indexes	3 analytics sub-docs, 4 indexes	DB design; the missing timestamp index
backend/models/user.js	User schema	generateApiKey (randomBytes(32).hex)	the unique-key discussion
backend/models/Group.js / GroupMember.js	Groups	script password note; unique compound index	join-table modelling, concurrency
backend/models/Goal.js / Team.js / Notification.js	Other entities	embedded members[] on Team	embedding vs referencing
backend/routes/extension.js	Ingest	/track, /track/batch, /verify, persistFlush, normalizeTerminalAnalytics	payload contract; 10-min bucket \$inc upsert; ACTIVITY_BUCKET_MS
backend/services/activityBucket.js	Bucketing (2026-09-08)	planActivityWrite, bucketStartFor, hasSignal, buildBucketUpdate	pure, unit-tested; event-log→rollup; \$inc atomicity; the correctness invariant
backend/models/DailySummary.js + services/dailySummary.js + services/dailyRollup.js + scripts/rollup-daily.js	Daily rollup (2026-09-08)	buildDaySummary (pure), rollupDaily (DB)	rollup infra for the all-time-read cutover

Path	Purpose	Key functions/classes	Interview relevance
backend/scripts/migrate-drop-date.js	One-off migration	drops date field + {userId:1,date:-1}	dry-run default; run on deploy
backend/routes/analytics.js	Dashboard reads	computeStreak, localDayInfo, buildTerminalSummary, resolveOwnedUserId	JS-vs-Mongo aggregation, timezones, streak
backend/routes/leaderboard.js	Global ranking	the all-collection aggregate + relative scoring	scalability (H-7), the rollup answer
backend/routes/metrics.js + services/metricsService.js + services/metricsDerive.js	Insights	buildMetrics, deepWorkRatio, consistencyIndex, truePeakWindow, estimationCalibration	"is this ML?"; pure-function testing
backend/routes/groups.js	Group lifecycle	create/join/leave/details, verifyPassword, opportunistic rehash	authz, concurrency, password handling
backend/routes/goals.js	Goals	/:goalId/progress owner scope	IDOR fix, progress formula
backend/routes/auth.js	OAuth + JWT	jwt.sign, cookie options	sessions vs JWT, CSRF
backend/routes/user.js	Profile + key	regenerate-api-key, complete-onboarding	key rotation
backend/routes/notifications.js	Notifications	all scoped by req.user._id	"the one that's done right"
backend/services/authorization.js	Authz helpers	sameUser, assertOwnership, isBypassAllowed	unit-tested, dependency-free
backend/services/passwordHash.js	Group pw hashing	crypto.scrypt, legacy plaintext	scrypt-over-bcrypt decision
backend/services/activityNormalizers.js	Ingest normalisers	normalizeEditor/Focus/GitAnalytics, MAX_FLOW_BLOCKS	additive schema evolution
backend/services/notificationScheduler.js	Cron	checkUpcomingDeadlines, checkOverdueGoals, daily rollupDaily, initScheduler	H-13 serverless problem (now also runs the rollup)
backend/tests/*.js	Tests	check() harness; static route scan; helper extraction	testing story
backend/server.js.old	Legacy monolith	had helmet + rate-limit; per-day upsert model	"what changed and why"
extension/src/extension.ts	Extension entry	activate, flushIfNeeded, buildPayload, sendActivity, start	the whole \$4

Path	Purpose	Key functions/classes	Interview relevance
extension/src/editorTracker.ts	Editor metrics	EditorTracker, consumeChurn, sampleAttention	churn algorithm, complexity
extension/src/focusTracker.ts	Focus/flow	FocusTracker, tick, accrue	flow-block state machine
extension/src/gitStateTracker.ts	Git	GitStateTracker, handleStateChange	using another extension's API
extension/src/terminalTracker.ts + analyticsAggregator.ts + commandClassifier.ts + gitTracker.ts	Terminal	classifyCommand, sanitizeCommand, recordExecution	privacy (sanitisation), classification
extension/src/debugTracker.ts	Debug	DebugTracker	folding a dead pipeline into the live one
extension/tests/*.js	Extension tests	stub-driven; activation.test.js regression guards	the packaging-bug story
frontend/src/App.tsx	Shell + auth gate	loadUserProfile, NavLink	routing, auth state
frontend/src/pages/Dashboard.tsx	Analytics UI	fetchAnalytics/Weekly/TimeSlot, chart configs	charts, the mock-data panel, M-11
frontend/src/pages/Insights.tsx	Insights UI	fetchMetrics, hasFocusData gating	graceful degradation for old data
frontend/src/pages/Leaderboard.tsx	Leaderboard UI	team-average derivation	derived state in render
frontend/src/pages/Groups.tsx	Groups UI	tabs, modals, join/leave	client-side flow
frontend/src/pages/Goals.tsx	Goals calendar	client-only todos, createGoal	half-built feature
frontend/src/pages/Profile.tsx	Key management	regenerateApiKey, copy	rotation UX
frontend/src/context/ThemeContext.tsx	Theming	28 palettes, CSS vars, useTheme	context, localStorage, the verbose-styles trade-off
frontend/src/components/NotificationPanel.tsx	Notifications	30 s poll, browser Notification API, click-outside	polling vs push, the stale-closure bug (L-1)
docs/IMPROVEMENT_PLAN.md	Self-audit	original 13 H / 13 M / 7 L; +4 added & fixed in the 2026-09-09 batch (M-14, M-15, L-8, L-9)	shows engineering maturity — reference it in interviews
docs/TRACKING_ROADMAP.md	Metrics design	signal tiers, derived-metric definitions, the AI-layer plan	where Insights came from; the LLM design

26. "Defend your project" — 30 interviewer exchanges

1. Why MongoDB?

Activity records are append-only, self-contained, and the schema evolved three times without a migration — I added editor/focus/git analytics sub-documents and Mongoose just defaults missing ones. The access pattern is "one user's docs in a time window, then aggregate" — no joins on the hot path. Plus Atlas has a free tier and the team knew it.

2. But Mongo has weaker relational guarantees — is that a problem here?

Yes, in the group/team/goal parts. `groupmembers` I modelled as a proper join table with a unique compound index, which is the one place I do get a hard guarantee. But `team.members` is an embedded array with a lost-update window, and I have no cascades — `groups.js` has defensive "filter out nulls if the group was deleted" code that a foreign key would remove. For those parts Postgres would genuinely be better.

3. Why not Postgres then?

If I were starting again with the relational features in mind, I might. The activity stream itself is still better as documents or a time-series table. The honest answer is the relational parts are small and the document parts are the bulk and the hot path.

4. Your leaderboard — what happens at 100k users?

It breaks. It aggregates the entire `activities` collection and loads every user into Node on every request, with no window, cache, or pagination. The fix is a `UserStats` rollup incremented on ingest so the leaderboard reads $O(\text{users})$ from an index, or a Redis sorted set for $O(\log n)$ rank lookups.

5. Why didn't you build the rollup already?

Time, and it wasn't the bottleneck at demo scale. It's the top item in my improvement plan. I'd rather ship the honest slow version and know exactly why it's slow than hand-wave.

6. Why not just cache the leaderboard?

A cache hides the cost, it doesn't remove it — the recompute still has to happen and it still scans everything. The rollup changes the complexity class; the cache is a nice addition on top for the top-N page.

7. Your API key — is that authentication?

It's a bearer credential. Possession authorises writes, there's no second factor, it's sent on every request. It's not "just an identifier" — an identifier would be safe to expose. It's an unscoped, non-expiring API token, and right now it's stored in plaintext.

8. What if someone steals another user's key?

They can forge unlimited activity for that user — inflate the leaderboard, corrupt the victim's analytics. They can't read the victim's dashboard, that needs the JWT cookie. Mitigation today is regeneration, which is all-or-nothing.

9. How would you fix the key model?

Hash it at rest with a `keyId` prefix so lookup is by an indexed id and comparison is constant-time on the hash. Support multiple named keys per device with independent revocation. Add rotation with a 24-hour grace window. Longer term, have the dashboard mint a short-lived signed ingest token the extension refreshes, or use an OAuth device flow so the extension never holds a long-lived secret.

10. Why not OAuth for the extension from the start?

A device flow is the right answer but it's more moving parts — a polling endpoint, token refresh, handling the "authorize in a browser" step inside VS Code. The API key was one `findOne` and worked offline. It's a legitimate MVP; I just wouldn't ship it to production unchanged.

11. Why not JWT between the extension and backend?

Same reason — a JWT needs an issue/refresh mechanism. If I keep the header model, I'd move to a short-lived JWT the dashboard issues, so at least it expires and is scoped.

12. Can users cheat the leaderboard?

Harder as of 2026-09-09: `/api/extension` is IP-rate-limited (120/min) and `duration` is capped at 3600/flush. But there's still no idempotency key or per-key quota, so one `curl` with a valid key and `duration: 999999` puts you at #1. Defences: validate `duration` (1–3600s), rate-limit per key, require an idempotency key per flush, and run anomaly detection on the duration-vs-edits ratio.

13. What happens if the extension sends the same payload twice?

It's stored twice and double-counted — there's no idempotency. A client-generated key per flush plus a unique index would dedupe it.

14. What happens if two requests arrive simultaneously?

Ingest is a single-document insert, so Mongo makes it atomic — fine. The problematic concurrent cases are double-join (caught by the unique index; the handler detects `error.code === 11000` and returns a 409 as of 2026-09-09, previously a 500) and `team.members.push` (a read-modify-write with a lost-update window — should be `$addToSet`).

15. Why aggregate analytics in Node instead of MongoDB?

Expedience while the metric definitions were still changing — `find().then(reduce)` is easy to debug. It's tech debt: it ships and parses every document and holds them all in memory. The metrics service already does it right with `$group` pipelines; the plan is to unify on that.

16. Why not calculate insights on the frontend?

The frontend would have to download every activity document to do it — huge payloads, and the raw data includes things I don't want to expose per-row. Aggregation belongs server-side near the data. The frontend just renders the numbers.

17. Is the Insights page machine learning?

No. It's deterministic statistics — median absolute deviation, surviving-minutes scoring for the productive two-hour window, medians, a median ratio for estimation accuracy, and a rules layer on top. I chose that so every number is explainable. An LLM narration layer is designed but not built, with a hard rule that any number it states must come from the metrics object.

18. Why use statistics instead of ML?

No labelled outcomes and not enough users to learn from. Descriptive stats work from the first data point, have no training pipeline, and are defensible in a code review. ML makes sense once I have goal-slippage or retention labels and a user base.

19. Why not use a simple rules engine for insights instead?

I did — on top of the metrics, not instead of them. `services/rulesEngine.js` holds 13 declarative threshold rules, e.g. churn above 30% *and* at least 10 points over your own 90-day norm → "you're rewriting more than usual". Each rule declares the metrics it needs and is skipped unless they clear the confidence gate — validated at startup, because `confidence !== 'insufficient'` is true for a missing entry. Every finding carries the numbers that fired it.

20. Why not use an LLM for the insights?

I want to — for the narration. Not for the numbers, because it would hallucinate them. The design has a validator that rejects any figure the model outputs that isn't in the structured metrics. That's the piece I haven't built.

21. Why MongoDB aggregation over `$lookup` for the leaderboard join?

I can't `$lookup` cleanly because `activities.userId` is a String and `users._id` is an ObjectId, so the pipeline groups by the string and I match users in Node by `String(_id)`. Migrating `userId` to ObjectId is on the list (M-6); then the join is native.

22. Why did you move from one insert per flush to 10-minute buckets?

The original per-flush model was ~1 row per 30–90s of coding — a two-hour session was ~100 tiny rows, each repeating the metadata plus four mostly-zero analytics objects. I changed ingest to an atomic `findOneAndUpdate` with `$inc` into a (user, project, language, 10-minute window) document. `$inc` in one update is atomic, unlike `server.js.old`'s read-then-`.save()` which had a lost-update race. I picked 10 minutes because that's the finest window any dashboard reads, so nothing lost resolution — and `$inc.duration` is the real measured seconds, so every total is identical. Row count dropped ~10×. A `DailySummary` nightly rollup exists for the long-tail all-time reads; repointing them at it is the follow-up.

23. Why not Redis?

Nothing needs it yet — leaderboard and insights recompute in under a second at current scale. It's the obvious next dependency: a sorted set for the leaderboard, a cache for insights, and rate-limit counters.

24. Why not a message queue for ingest?

One write per user per minute is well within a single Mongo node. A queue earns its keep when ingest spikes threaten write latency or when I want to replay/repair — past ~10k concurrent users.

25. Why not WebSockets for notifications?

The `NotificationPanel` polls every 30 seconds, which is fine for deadline reminders. I'd add WebSockets for real-time group activity, not for this.

26. Why not microservices?

One developer, one deploy, one database, and the features genuinely share the data model. Splitting them would add network hops and distributed-transaction problems for no benefit. The one service I'd extract first is ingest, behind a queue, when volume demands it.

27. Your frontend build — walk me through the cleanup.

It had 29 pre-existing TypeScript errors — mostly unused imports and variables, plus 5 implicit-any props in one decorative component (`TextType.tsx`) that also produced 4 `string not assignable to never` errors where pages passed `textColors`. Fixed 2026-09-09; `npm run build` is green and CI keeps it that way. Historically the two real `string not assignable to never` cases. They predate my security work. `vite build` alone always succeeded; the combined `tsc -b && vite build` used to fail. It was a cleanup pass; it's filed as M-13.

28. You have `@tanstack/react-query` installed but unused. Why?

It was added intending to adopt it and I didn't finish. Right now every navigation refetches with `cache: 'no-cache'`. Wiring React Query is a medium-term item — it'd give caching, dedup, and retry with almost no new code.

29. How do you know your aggregation pipelines are correct if nothing ran against a real DB?

I don't, fully — that's stated in the session log. The pure functions (`metricsDerive`, `normalisers`, `authorization`, `streak helpers`) are unit-tested, and `streak.test.js` extracts the *shipped* code rather than a copy so it catches regressions. But there's no integration test booting Express against a real Mongo. That's the biggest testing gap and it's on the plan — `supertest + mongodb-memory-server`.

30. If this got 10,000 real users tomorrow, what's your first move?

Add the `{userId:1,timestamp:-1}` index and put a 30-day window + `$limit` on the leaderboard pipeline as a stopgap, then build the `UserStats` rollup. In parallel: `helmet` + rate limiting so ingest can't be flooded, and `express-validator` so duration can't be faked. Then a `/health` that fails readiness when Mongo is down, and a real logger so I can see what's happening.

27. Final self-audit

- ✓ Whole repository inspected — backend (all routes/models/services/tests), extension (all `src/*.ts` + tests), frontend (all pages + key components + context), config, docs.
- ✓ Extension traced end to end: activation → trackers → flush loop → payload → POST.
- ✓ Extension → API → MongoDB path traced (`verifyApiKey` → `normalisers` → `Activity.create`).
- ✓ Every model examined; index gap identified (`timestamp` vs `date`).
- ✓ Every meaningful API endpoint tabulated with auth + processing.
- ✓ Frontend architecture, state model, and the three real bugs (mock panel, unpersisted todos, orphaned Teams) documented.
- ✓ Leaderboard analysed ($O(A+U)$, relative scoring, email exposure) + the rollup answer.
- ✓ Groups analysed (join table, membership check, double-join → 409 (fixed 2026-09-09), no admin role).
- ✓ Insights analysed in full — confirmed **statistics, not ML**; LLM layer designed not built.

- ✓ Auth analysed — Google OAuth → JWT cookie (web), API key (extension), no refresh, no revocation. (JWT_SECRET fallback fixed 2026-09-09.)
- ✓ Unique key analysed — classified as an unscoped non-expiring plaintext bearer credential; attack scenarios + redesign.
- ✓ Security: separated fixed (H-1/2/9/10/11) from open (keys, rate limit, headers, validation, error leakage, email exposure, idempotency, regex ReDoS).
- ✓ Scalability: 10k / 100k / 1M analysis with concrete evolution.
- ✓ Limitations: current vs production, each with impact + fix.
- ✓ No invented implementation details — everything marked ACTUAL or RECOMMENDED.
- ✓ Source files referenced throughout + a codebase map.
- ✓ Deliverables created: this file, CodeTrackr_Interview_QA.md, CodeTrackr_Architecture.md, CodeTrackr_Interview_Cheat_Sheet.md, ../../CODETRACKR_PROJECT_CONTEXT.md, and the PDF.

Biggest interview risks to rehearse

1. **The API key** — know the identifier-vs-credential distinction cold, and the redesign.
2. **The leaderboard scan** — know the exact complexity and the rollout / sorted-set answer.
3. **"Is it ML?"** — say no, confidently, and explain why that was the right call.
4. **The broken frontend build** — own it, it's a cleanup not a design flaw.
5. **Nothing tested against a real DB** — own it, name the fix (supertest + memory server).
6. **"What did you build?"** — describe what you can defend in depth; don't over-claim.

28. Core computer-engineering subjects — where each one actually appears

Interviewers often ask "which subjects did you actually use?" This maps each one to a **specific file and a specific decision**, so the answer is concrete rather than a list of course names. Everything here points at code that exists; §28.11 says plainly what the project does *not* demonstrate.

Subject	Where it shows up	The one-line answer
DBMS	models/Activity.js, services/metricsService.js	Compound-index field order, a partial-unique index used as a concurrency guard, TTL, and aggregation pipelines
Operating systems	services/activityBucket.js, app.js, extension/src/extension.ts	Race conditions and atomicity without threads; why a timer-based scheduler dies on serverless
Computer networks	app.js, routes/auth.js, extension/src/extension.ts	CORS, cookie flags, TLS, rate limiting, and at-least-once delivery over plain HTTP
Theory of computation	services/textQuery.js	A regex is an automaton — catastrophic backtracking is a real denial of service
Algorithms	services/metricsDerive.js, routes/leaderboard.js	Sliding-window argmax, gap-splitting, and an $O(A + U)$ scan that fails at the argument limit

Subject	Where it shows up	The one-line answer
Probability & statistics	<code>services/metricsDerive.js</code>	Median and MAD over mean and standard deviation, plus sample-size gating
Information security	<code>services/passwordHash.js</code> , <code>routes/internal.js</code> , <code>middleware/auth.js</code>	script, constant-time comparison, JWT, IDOR, and an honest threat model of the API key
Software engineering	<code>backend/tests/</code> , <code>docs/IMPROVEMENT_PLAN.md</code>	Pure functions split from I/O so they are testable; regression tests that encode past bugs
Distributed systems	<code>routes/extension.js</code> , <code>services/dailyRollup.js</code>	Exactly-once is not free; clock skew, idempotency, and eventual consistency

28.1 DBMS

- **Index design.** `{ userId: 1, timestamp: -1 }` follows equality-then-range: every read filters one user over a date range. Before it existed those queries fell back to the `userId` index and filtered in memory. Measured with `.explain()`: IXSCAN, 32 keys examined for 32 returned.
- **A unique index as a concurrency control.** `{userId, projectName, language, bucketStart}` is **partial** (`bucketStart: {$exists: true}`) so it constrains only bucketed documents. A duplicate key (`11000`) is not an error to hide — it is the database refusing a lost update, and the group join route turns the same signal into a `409`.
- **Aggregation vs application code.** `metricsService.js` pushes `$match/$group` into the engine; most of `routes/analytics.js` still pulls documents and reduces in JavaScript (M-1). The contrast between the two is the best "why does this matter" example in the codebase.
- **Materialised views.** `dailysummaries` is a nightly rollup — precomputed aggregates traded against staleness, the classic read/write amplification decision.
- **No transactions.** MongoDB gives atomicity per document, so the design leans on single-document `$inc` upserts instead of multi-document transactions. `Team.members.push()` + `save()` is a read-modify-write and *can* lose an update under concurrency — a known, documented gap.

28.2 Operating systems

- **Concurrency without threads.** Node is a single-threaded event loop, so there are no data races inside the process — but there are absolutely races *at the database*, between concurrent requests. The fix is atomicity in the store (`findOneAndUpdate + $inc`), not a mutex.
- **Blocking the loop is fatal.** One thread serves every request, which is exactly why the ReDoS in §28.4 was severe: one bad regex stalls all users, not just the attacker.
- **Process lifecycle.** `node-cron` assumes a long-lived process. On a serverless host the process is frozen between requests, so the hourly job never fires and every cold start re-runs the startup sweep. Fixed by guarding on `require.main === module` and moving the schedule to an external trigger — a scheduling problem solved by understanding the process model.
- **Idle detection.** The extension's flush loop distinguishes wall-clock time from *active* time, pausing its samplers after two minutes idle. Getting this wrong added five idle hours to a metric.

28.3 Computer networks

- **CORS** is an allowlist of origins with credentialed requests, which is why a Vercel preview deployment cannot call the API: a different origin is rejected before the handler runs.

- **Cookies as a transport decision.** `httpOnly` (unreadable to JavaScript, so XSS cannot steal the session), `Secure`, and `SameSite=None` because the SPA and API are on different domains.
- **Rate limiting** is per-IP with a window — and `trust proxy` matters, because behind a proxy the client IP is in `X-Forwarded-For`, not the socket.
- **Delivery semantics.** The extension posts fire-and-forget over HTTP. Without an idempotency key a retry double-counts, which is the at-least-once vs exactly-once distinction in miniature.
- **Latency is not uniform.** A cold Render instance answers in ~22 s versus ~200 ms warm; the cron workflow retries with a delay for exactly this reason.

28.4 Theory of computation

The group search put user input straight into a regular expression. Two consequences follow directly from formal-language theory:

- A regex is compiled to a **backtracking automaton**. A pattern like `(a+)+$` against a non-matching string explores exponentially many paths — **catastrophic backtracking**. One request pins the event loop (§28.2) and the whole service stops. That is a denial of service from a string, with no exploit code.
- Escaping every metacharacter reduces the pattern to a **literal string match**, which is linear. `textQuery.js` does that, and the test asserts `(a+)+$` against a 4,000-character input returns in under 500 ms once escaped.

28.5 Algorithms

- **Complexity that bites.** The leaderboard is $O(A + U)$ — every activity document plus every user — per request, with an $O(U \log U)$ sort. Fine at 7,000 documents, fatal at scale; the fix is a rollup that makes it $O(U)$.
- **Argument limits are a real bound.** `Math.max(...array)` spreads one argument per element and throws `RangeError` past roughly 100k. Replaced with a fold — a reminder that language-level limits are part of complexity analysis in practice.
- **Sliding window.** `truePeakWindow` is an argmax over 24 two-hour windows, scored on "surviving minutes".
- **Gap splitting.** Sessionization collapses documents by bucket, then walks them in order and cuts wherever the gap exceeds 30 minutes — one linear pass.
- **Backward walk.** `qualityStreak` anchors on today or yesterday and walks back through a `Set` of day keys, so each lookup is $O(1)$.

28.6 Probability and statistics

- **Robust statistics.** The consistency metric used $1 - \text{stddev}/\text{mean}$ — the coefficient of variation — which one ten-hour Saturday can dominate. It is now $1 - \text{MAD}/\text{median}$: median absolute deviation is robust to outliers. The test asserts `[60,60,60,60,600]` still scores ≥ 0.9 .
- **Median over mean** for estimation calibration, so a single runaway goal cannot skew the figure.
- **Sample size is part of the answer.** Every metric ships a confidence level derived from its own sample count. Below the minimum, the UI shows — rather than a number. Three days of data must not render identically to six months.
- **Survivorship in the data.** The daily aggregate emits no row for a day with zero activity, so a statistic computed over it silently measures only active days — the exact bug behind two wrong metrics.

28.7 Information security

- **Password storage.** Group passwords use **scrypt** — a memory-hard KDF with a per-password salt, stored as `scrypt$salt$hash`. Memory-hard matters because it degrades GPU attacks specifically.
- **Constant-time comparison.** The cron secret is checked with `crypto.timingSafeEqual`, and the route answers **404** rather than 401 when the secret is wrong, so it is not discoverable. A naive `===` leaks the secret one byte at a time through response timing.
- **Tokens.** A JWT is a signed, self-contained claim — the server verifies a signature instead of looking up a session. The trade-off is revocation: you cannot invalidate one before it expires.
- **IDOR.** `/api/metrics` deliberately takes **no** `:userId`; identity comes from the session, so the whole class of "change the id in the URL" bugs cannot exist there.
- **Honest threat modelling.** The API key is an unscoped, non-expiring, plaintext bearer credential. Stealing it lets an attacker forge activity but not read the victim's dashboard, which needs the JWT. Naming the blast radius precisely is the skill being demonstrated.

28.8 Software engineering

- **Pure functions separated from I/O.** All the metric maths lives in `metricsDerive.js` with no database access, so the 375 unit assertions run in seconds with no database. Since 2026-10-03, 41 integration tests also run the real app against an in-memory MongoDB, since 2026-10-04 52 frontend tests run in Vitest, and one refactor was proven by running the old code as an oracle next to the new one.
- **Regression tests encode history.** Several tests exist only because a specific bug shipped — one asserts that `Math.max(...spread)` really does throw at 200k elements, so the reason for the replacement cannot be lost.
- **Architectural guard rails.** `routeGuards.test.js` statically scans route source and fails if a sensitive route loses its auth middleware — a test for a property, not a behaviour.
- **A written debt register.** `docs/IMPROVEMENT_PLAN.md` tracks every finding by severity with its fix and verification. The register itself is the artefact worth showing.

28.9 Distributed systems

- **Two clocks.** The client stamps `timestamp`; the server bounds it to `[now-24h, now+60s]` because clock skew and malice are the same problem from the server's point of view.
- **Idempotency.** Ingest is at-least-once. Since 2026-10-03 each upload carries a client-generated `flushId` and a unique receipt index makes a retry apply once — the standard way to make an at-least-once channel behave as exactly-once. An atomic `$inc` counter caps credited time per window without a read-then-write race.
- **Eventual consistency.** The rollup runs nightly against days older than two, so summaries lag reality by design. Reads that need "now" go to the raw collection.
- **Stateless services.** No in-process state survives a restart, which is what makes horizontal scaling possible — and what forced the scheduler out of the process.

28.10 A caveat worth volunteering: compiler design

`commandClassifier.ts` tokenises a shell command and classifies it by category, which is tokenisation and rule-based classification — the nearest thing here to lexical analysis. It is not a parser, there is no grammar and no AST. Say that plainly rather than dressing it up.

28.11 What this project does *not* demonstrate

Volunteering this is worth more than padding the list above:

- **No machine learning.** Deterministic statistics with a threshold-rule layer. No model, no training, no inference. A work-type classifier (logistic regression on one-tap user labels; it replaced the earlier k-means idea on 2026-09-17) is designed in `docs/ML_INTEGRATION_PLAN.md` and deliberately not built — it needs ~300 labelled sessions from 10+ people.
- **No OS-level concurrency** — no threads, locks, or shared memory. Concurrency here is I/O scheduling and database atomicity.
- **No distributed consensus, sharding, or replication** beyond what Atlas provides.
- **No compiler or interpreter work** beyond the tokeniser above.
- **No formal verification or queueing theory.** Performance evidence is two local benchmarks (`docs/BENCHMARKS.md`: leaderboard 6.7 s → 62 ms at 1M rows; bucketing ~5× fewer documents) — measured on one laptop, not in production.